

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



Práctica: OpenSCAP | Nessus

Informe de práctica

Víctor José Santos Guzmán

Information Security

Cybersecurity / Cloud / Networks / GRC

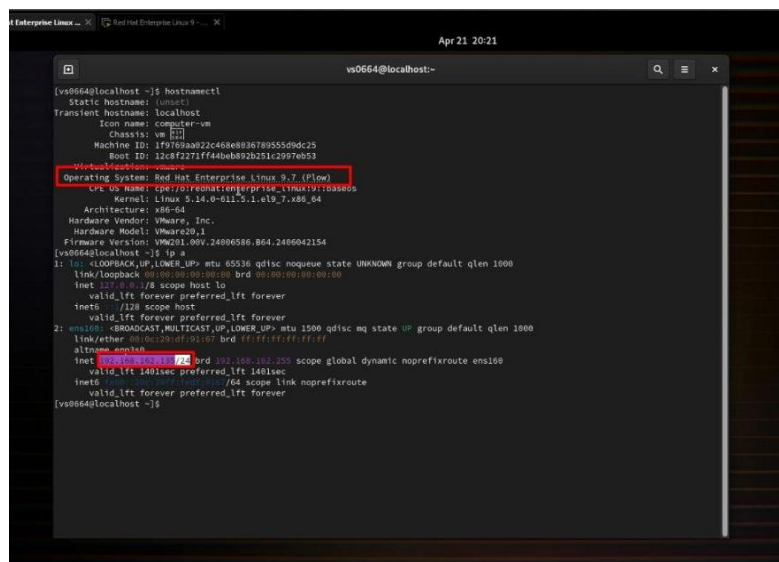


Introducción a OpenSCAP

OpenSCAP es un framework de código abierto diseñado para la gestión de cumplimiento y auditoría de seguridad en entornos Linux. Utiliza el estándar SCAP (Security Content Automation Protocol) para automatizar la evaluación de configuraciones y la detección de vulnerabilidades, permitiendo no solo identificar brechas respecto a normativas como PCI-DSS, sino también generar scripts de remediación automáticos para blindar la infraestructura de manera estandarizada y eficiente.

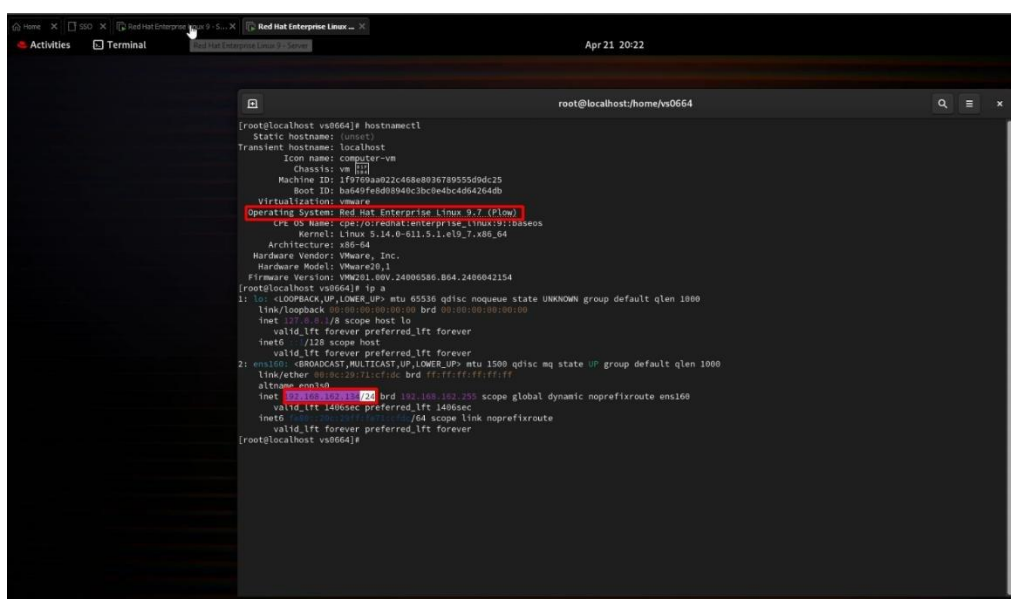


Paso 1: Comienzo verificando la identidad de mi servidor principal mediante el comando `hostnamectl`, donde confirmo que opero sobre Red Hat Enterprise Linux 9.7 (Plow) bajo la arquitectura x86_64. Adicionalmente, ejecuto `ip a` para validar mi direccionamiento de red, identificando la interfaz `ens160` con la dirección IP `192.168.162.134/24`, la cual servirá como el nodo central para la gestión de las políticas de cumplimiento.



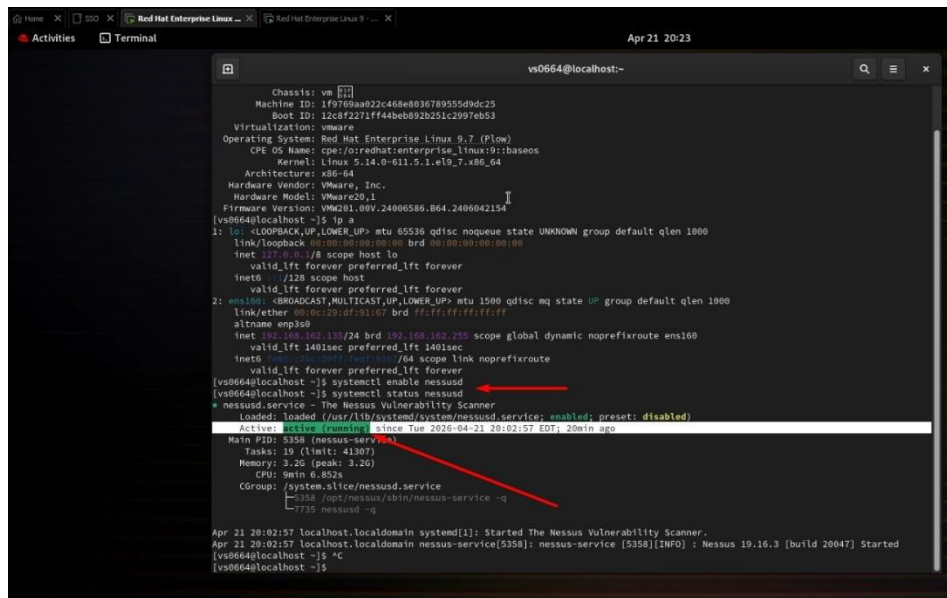
```
vs0664@localhost:~$ hostnamectl
[vs0664@localhost ~]$ hostnamectl
Static hostname: localhost
Transient hostname: localhost
Icon name: computer-vn
Chassis: vm
Machine ID: 1f9709aa022c468e8936789555d9dc25
Boot ID: 12c8f2271ff44beb892b251c2997eb53
Operating System: Red Hat Enterprise Linux 9.7 (Plow)
CPE OS Name: cpe:/o:redhat:enterprise-linux:9:baseos
Kernel: Linux 5.14.0-0113.1.el9_7.x86_64
Architecture: x86_64
Hardware Vendor: VMware, Inc.
Hardware Model: VMWare20.1
Firmware Version: VMW20.1.06V.24006586.B64.2406042154
[vs0664@localhost ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether ba:49:fe:d9:89:4c brd ff:ff:ff:ff:ff:ff
    altname ens160
    inet 192.168.162.134/24 scope global dynamic noprefixroute ens160
        valid_lft 1406sec preferred_lft 1406sec
    inet6 fe80::ba49:fe:d9:89:4c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
[vs0664@localhost ~]$
```

Paso 2: De igual manera, accedo al equipo cliente para asegurar la conectividad y verificar su hostname, confirmando que corre la misma distribución de Red Hat necesaria para la práctica. Utilizo nuevamente `ip a` para constatar que este nodo posee la IP `192.168.162.135/24`, estableciendo así el mapa de red necesario para que el servidor de OpenSCAP pueda realizar los escaneos remotos y las aplicaciones de parches de seguridad.



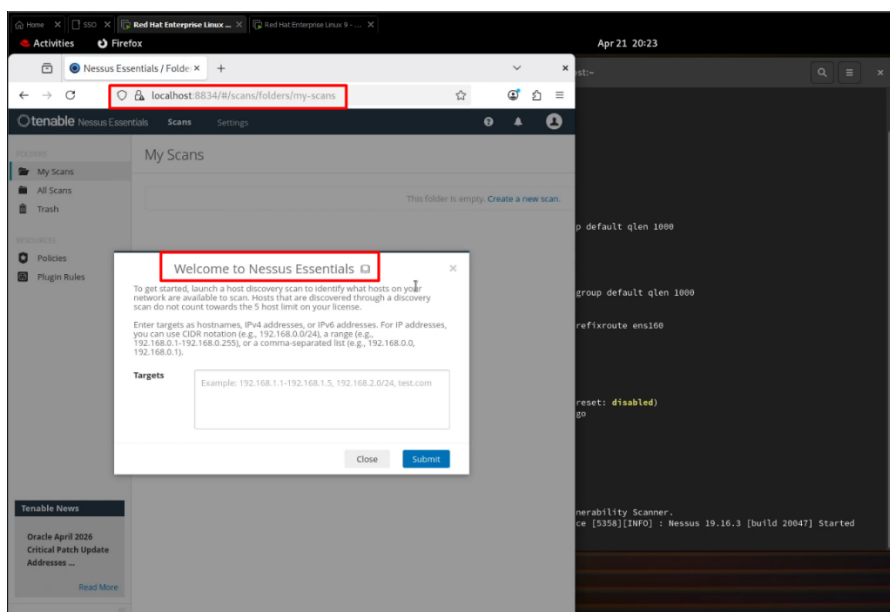
```
root@localhost:~$ hostnamectl
[root@localhost ~]$ hostnamectl
Static hostname: localhost
Transient hostname: localhost
Icon name: computer-vn
Chassis: vm
Machine ID: 1f9709aa022c468e8936789555d9dc25
Boot ID: ba549fe8d98948c3bce4bc4d64264db
Virtualization: vmware
Operating System: Red Hat Enterprise Linux 9.7 (Plow)
CPE OS Name: cpe:/o:redhat:enterprise-linux:9:baseos
Kernel: Linux 5.14.0-0113.1.el9_7.x86_64
Architecture: x86_64
Hardware Vendor: VMware, Inc.
Hardware Model: VMWare20.1
Firmware Version: VMW20.1.06V.24006586.B64.2406042154
[root@localhost ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether ba:49:fe:d9:89:4c brd ff:ff:ff:ff:ff:ff
    altname ens160
    inet 192.168.162.135/24 scope global dynamic noprefixroute ens160
        valid_lft 1406sec preferred_lft 1406sec
    inet6 fe80::ba49:fe:d9:89:4c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
[root@localhost ~]$
```

Paso 3: Procedo a habilitar y verificar el estado del escáner de vulnerabilidades mediante los comandos `systemctl enable nessusd` y `systemctl status nessusd`, confirmando que el servicio está active (running). Al estar el daemon en ejecución desde hace 20 minutos, garantizo que la plataforma esté lista para realizar el análisis previo de seguridad sobre el cliente y detectar las debilidades que OpenSCAP deberá mitigar posteriormente.

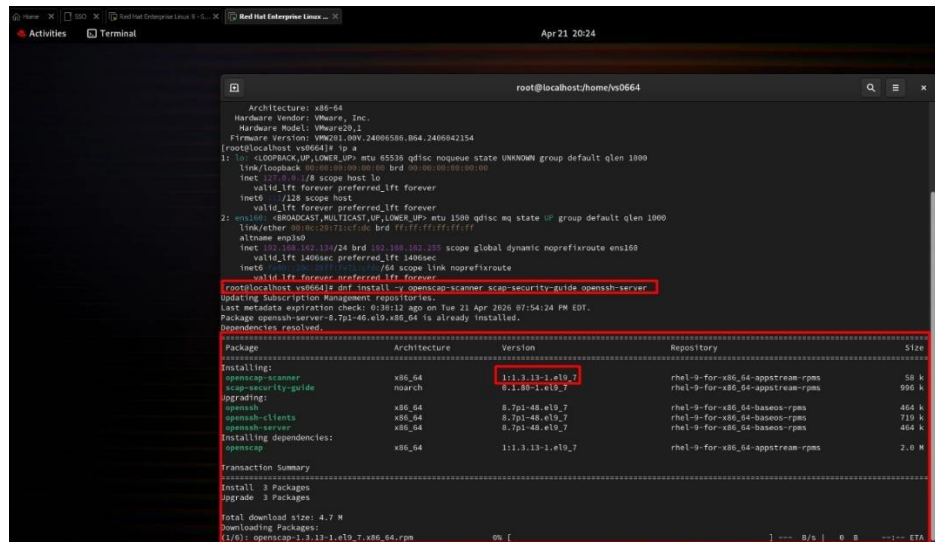


```
vs0664@localhost:~  
Chassis: vm  
Machine ID: 1f876aa822c468e803678955d9dc25  
Boot ID: 12c8f2271ff44beb892b251c2997eb53  
Virtualization: vmware  
Operating System: Red Hat Enterprise Linux 9.7 (Plow)  
CPU OS Name: cpe:/o:redhat:enterprise_linux:9::baseos  
Kernel: Linux 5.14.0-611.5.1.el9_7.x86_64  
Architecture: x86_64  
Hardware Vendor: VMware, Inc.  
Hardware Model: VMWare20.1  
Firmware Version: VMW201.08V.24006586.B64.2406042154  
[vs0664@localhost ~]$ systemctl enable nessusd  
[vs0664@localhost ~]$ systemctl status nessusd  
● nessus.service - The Nessus Vulnerability Scanner  
   Loaded: loaded (/usr/lib/systemd/system/nessus.service; enabled; preset: disabled)  
   Active: active (running) since Tue 2026-04-21 20:02:57 EDT; 20min ago  
     Main PID: 5358 (nessus-service)  
       Tasks: 19 (limit: 41307)  
      Memory: 3.2G (peak: 3.2G)  
         CPU: 9min 6.852s  
        CGroup: /system.slice/nessus.service  
                └─5358 /opt/nessus/sbin/nessus-service -q  
                  └─7735 nessusd --q  
  
Apr 21 20:02:57 localhost.localdomain systemd[1]: Started The Nessus Vulnerability Scanner.  
Apr 21 20:02:57 localhost.localdomain nessus-service[5358]: nessus-service [5358][INFO] : Nessus 19.16.3 [build 20047] Started  
[vs0664@localhost ~]$
```

Paso 4: Accedo mediante el navegador Firefox a la URL <https://localhost:8834>, donde se despliega la interfaz de bienvenida de Nessus Essentials lista para configurar un nuevo análisis de red. En este punto, me preparo para ingresar el rango de IPs o el host específico del cliente en la sección de "Targets", con el fin de identificar brechas críticas o configuraciones inseguras que vulneren el estándar PCI-DSS solicitado.

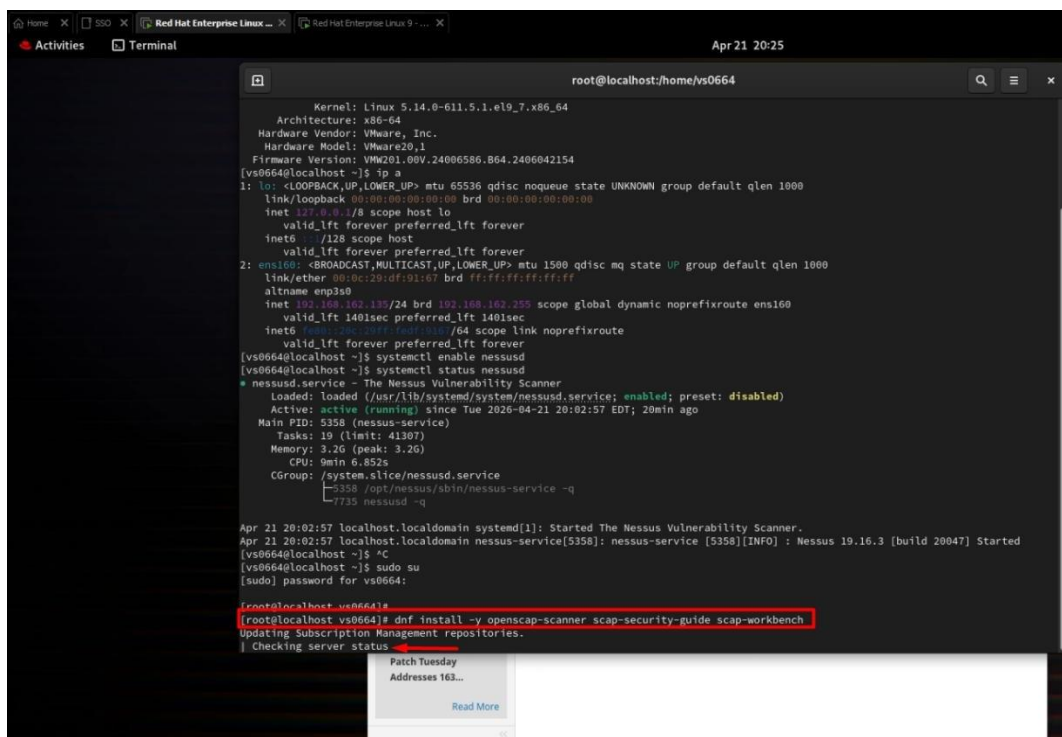


Paso 5: Ejecuto el comando `dnf install -y openscap-scanner scap-security-guide openssh-server` para dotar al sistema de los binarios necesarios para el análisis de cumplimiento y la comunicación remota. En la salida de la terminal, observo cómo se descargan e instalan paquetes clave como `openscap-1.3.13` y las guías de seguridad de Red Hat, elementos fundamentales para poder interpretar y aplicar los perfiles de endurecimiento del sistema.



```
root@localhost/home/vs0664
Architecture: x86_64
Hardware Vendor: VMware, Inc.
Hardware Model: VMWare20,1
Firmware Version: VMW20,1.00V.24006586.B64.2406042154
[vs0664@localhost ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:0c:29:d1:91:67 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.102.135/24 brd 192.168.102.255 scope global dynamic noprefixroute ens160
        valid_lft 1401sec preferred_lft 1401sec
    inet6 fe80::c01:1:1:1:1:1:1:1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
root@localhost/home/vs0664# dnf install -y openscap-scanner scap-security-guide openssh-server
Updating Subscription Management repositories.
Last metadata expiration check: 6:30:12 ago on Tue 21 Apr 2026 07:54:24 PM EDT.
Package openssh-server-8.7p1-48.el9.x86_64 is already installed.
Dependencies resolved.
=====
Package                Architecture      Version              Repository            Size
=====
Installing:
openscap-scanner        x86_64            1:1.3.13-1.el9_7    rhel-9-for-x86_64-appstream-rpms    58 k
scap-security-guide     noarch            4.1.80-1.el9_7      rhel-9-for-x86_64-appstream-rpms    990 k
Upgrading:
openssh                 x86_64            8.7p1-48.el9_7      rhel-9-for-x86_64-basos-rpms        464 k
openssh-clients         x86_64            8.7p1-48.el9_7      rhel-9-for-x86_64-basos-rpms        719 k
openssh-server          x86_64            8.7p1-48.el9_7      rhel-9-for-x86_64-basos-rpms        464 k
Installing dependencies:
openscap                x86_64            1:1.3.13-1.el9_7    rhel-9-for-x86_64-appstream-rpms    2.0 M
Transaction Summary
-----
Install  3 Packages
Upgrade  0 Packages
Total download size: 4.7 M
Downloading Packages:
(1/6): openscap-1.3.13-1.el9_7.x86_64.rpm    0% [
] 0.0 B/s | 0 B | ETA: 0:00:00
=====
```

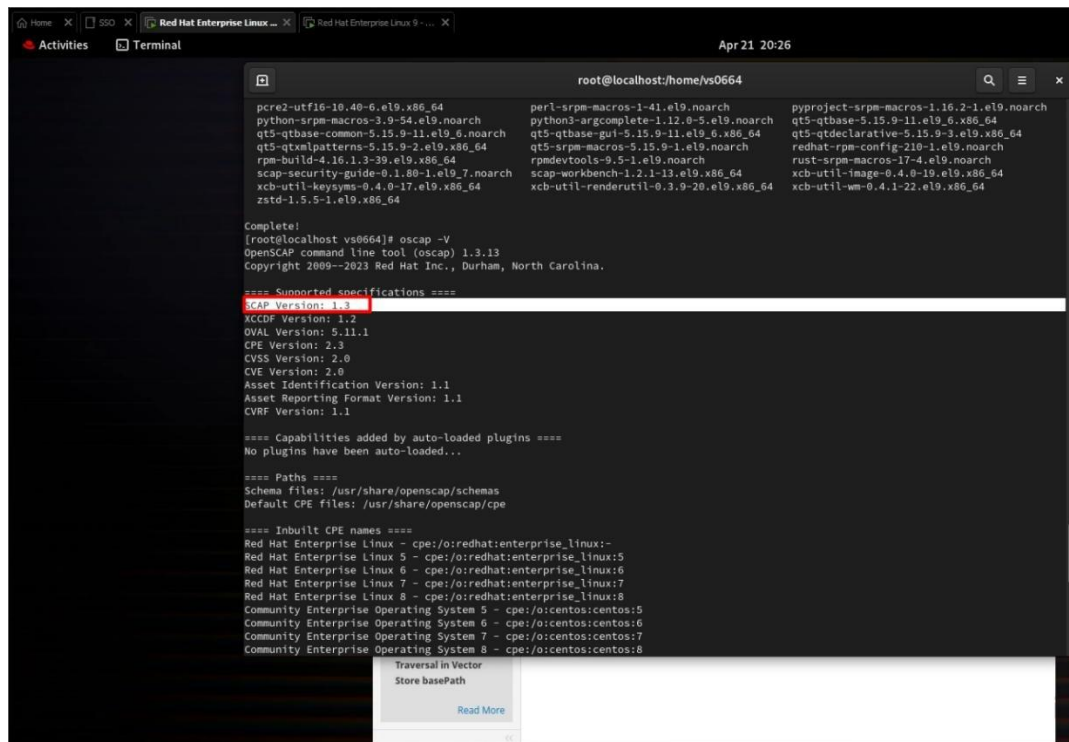
Paso 6: Utilizo nuevamente el gestor de paquetes mediante `dnf install -y openscap-scanner scap-security-guide scap-workbench` para asegurar que la herramienta gráfica de auditoría esté presente en mi servidor de seguridad.



```
Kernel: Linux 5.14.0-611.5.1.el9_7.x86_64
Architecture: x86_64
Hardware Vendor: VMware, Inc.
Hardware Model: VMWare20,1
Firmware Version: VMW20,1.00V.24006586.B64.2406042154
[vs0664@localhost ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:0c:29:d1:91:67 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.102.135/24 brd 192.168.102.255 scope global dynamic noprefixroute ens160
        valid_lft 1401sec preferred_lft 1401sec
    inet6 fe80::c01:1:1:1:1:1:1:1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
[vs0664@localhost ~]$ systemctl enable nessusd
[vs0664@localhost ~]$ systemctl status nessusd
* nessusd.service - The Nessus Vulnerability Scanner
    Loaded: loaded (/usr/lib/systemd/system/nessusd.service; enabled; preset: disabled)
    Active: active (running) since Tue 2026-04-21 20:02:57 EDT; 20min ago
    Main PID: 5358 (nessus-service)
    Tasks: 19 (limit: 41307)
    Memory: 3.2G (peak: 3.2G)
    CPU: 9min 6.852s
    CGroup: /system.slice/nessusd.service
            └─5358 /opt/nessus/sbin/nessus-service -q
              └─7735 nessusd -q

Apr 21 20:02:57 localhost.localdomain systemd[1]: Started The Nessus Vulnerability Scanner.
Apr 21 20:02:57 localhost.localdomain nessus-service[5358]: nessus-service [5358][INFO] : Nessus 19.16.3 [build 20047] Started
[vs0664@localhost ~]$ %C
[vs0664@localhost ~]$ sudo su
[sudo] password for vs0664:
root@localhost/home/vs0664#
root@localhost/home/vs0664# dnf install -y openscap-scanner scap-security-guide scap-workbench
Updating Subscription Management repositories.
Checking server status
Patch Tuesday
Addresses 163...
Read More
```

Paso 7: Valido la correcta instalación del framework ejecutando el comando `oscap -V`, donde el sistema me confirma que estoy utilizando la SCAP Version: 1.3 y el motor de línea de comandos 1.3.13.



```
root@localhost/home/vs0664

pcre2-utf16-10.40-6.el9.x86_64      perl-srpm-macros-1.41.el9.noarch    pyproject-srpm-macros-1.16.2-1.el9.noarch
python-srpm-macros-3.9-54.el9.noarch python3-argcomplete-1.12.0-5.el9.noarch qt5-qtdbase-5.15.9-11.el9.x86_64
qt5-qtdbase-common-5.15.9-11.el9.x86_64 qt5-qtdbase-gui-5.15.9-11.el9.x86_64 qt5-qtddeclarative-5.15.9-3.el9.x86_64
qt5-qtdpatterns-5.15.9-2.el9.x86_64    qt5-srpm-macros-5.15.9-1.el9.noarch  redhat-rpm-config-210-1.el9.noarch
rpm-build-4.16.1.3-39.el9.x86_64      rpmdevtools-9.5-1.el9.noarch       rust-srpm-macros-17-4.el9.noarch
scap-security-guide-0.1.80-1.el9.7.noarch scap-workbench-1.2.1-13.el9.x86_64  xcb-util-image-0.4.0-19.el9.x86_64
xcb-util-keysyms-0.4.0-17.el9.x86_64  xcb-util-renderutil-0.3.9-20.el9.x86_64 xcb-util-wm-0.4.1-22.el9.x86_64
zstd-1.5.5-1.el9.x86_64

Complete!
[root@localhost vs0664]# oscap -V
OpenSCAP command line tool (oscap) 1.3.13
Copyright 2009--2023 Red Hat Inc., Durham, North Carolina.

==== Supported specifications ====
XCCDF Version: 1.2
OVAL Version: 5.11.1
CPE Version: 2.3
CVSS Version: 2.0
CVE Version: 2.0
Asset Identification Version: 1.1
Asset Reporting Format Version: 1.1
CVRF Version: 1.1

==== Capabilities added by auto-loaded plugins ====
No plugins have been auto-loaded...

==== Paths ====
Schema files: /usr/share/openscap/schemas
Default CPE files: /usr/share/openscap/cpe

==== Inbuilt CPE names ====
Red Hat Enterprise Linux - cpe:/o:redhat:enterprise_linux:-
Red Hat Enterprise Linux 5 - cpe:/o:redhat:enterprise_linux:5
Red Hat Enterprise Linux 6 - cpe:/o:redhat:enterprise_linux:6
Red Hat Enterprise Linux 7 - cpe:/o:redhat:enterprise_linux:7
Red Hat Enterprise Linux 8 - cpe:/o:redhat:enterprise_linux:8
Community Enterprise Operating System 5 - cpe:/o:centos:centos:5
Community Enterprise Operating System 6 - cpe:/o:centos:centos:6
Community Enterprise Operating System 7 - cpe:/o:centos:centos:7
Community Enterprise Operating System 8 - cpe:/o:centos:centos:8

Traversal in Vector
Store basePath
Read More
```

Paso 8: Continúo analizando la salida técnica de `oscap -V`, desplazándome por la lista de objetos OVAL y sus respectivos probes, como `file_probe`, `partition_probe` y `selinux_probe`. Esta verificación es vital para confirmar que el motor tiene la capacidad de inspeccionar variables críticas como contraseñas



```
XCCDF Version: 1.2
OVAL Version: 5.11.1
CPE Version: 2.3
CVSS Version: 2.0
CVE Version: 2.0
Asset Identification Version: 1.1
Asset Reporting Format Version: 1.1
CVRF Version: 1.1
```

Paso 9: Con el fin de asegurar que el cliente sea accesible para el escaneo remoto y para provocar o corregir vulnerabilidades manuales, ejecuto el comando `nano /etc/ssh/sshd_config` para editar los parámetros del servicio

```

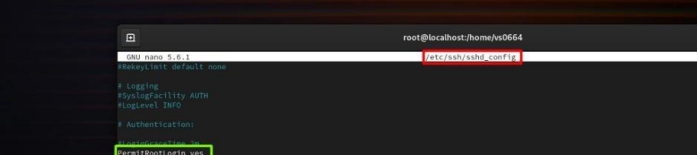
Fedora 35 - cpe:/o:fedora:project:fedora:35

=== Supported OVAL objects and associated OpenSCAP probes ===
OVAL family      OVAL object                                     OpenSCAP probe
-----
independent      environmentvariable      probe.environmentvariable
independent      environmentvariabless    probe.environmentvariabless
independent      family                   probe.family
independent      filesha512               probe.filesha512 (SHA-224, SHA-256, SHA-384, SHA-512)
independent      system_info             probe.system_info
independent      textfilecontent         probe.textfilecontent
independent      textfilecontent54       probe.textfilecontent54
independent      variable                probe.variable
independent      yamlfilecontent         probe.yamlfilecontent
independent      ymlisteners             probe.ymlisteners
linux            inetlisteningservers    probe.inetlisteningservers
linux            partition               probe.partition
linux            rpminfo                 probe.rpminfo
linux            rpmverify               probe.rpmverify
linux            rpmverifyfile           probe.rpmverifyfile
linux            rpmverifypackage        probe.rpmverifypackage
linux            selinuxboolean          probe.selinuxboolean
linux            selinuxsecuritycontext  probe.selinuxsecuritycontext
linux            systemdunitdependency   probe.systemdunitdependency
linux            systemdunitproperty     probe.systemdunitproperty
linux            fwopdecstr              probe.fwopdecstr
linux            dnscache                probe.dnscache
linux            file                    probe.file
linux            fileextendedattribute   probe.fileextendedattribute
linux            interface               probe.interface
linux            password                probe.password
linux            process                 probe.process
linux            routingslab             probe.routingtable
linux            runlevel                probe.runlevel
linux            shadow                  probe.shadow
linux            symlink                 probe.symlink
linux            systemctl               probe.systemctl
linux            uname                   probe.uname
linux            xinetd                  probe.xinetd

[root@localhost ~]#
[root@localhost ~]# cd /etc/ssh/ssh_config

```

Paso 10: Dentro del editor de texto en `/etc/ssh/sshd_config`, localizo y modifico las directivas `PermitRootLogin` y `PasswordAuthentication`, estableciéndolas temporalmente en "yes" para permitir las pruebas iniciales. Soy consciente de que estas configuraciones son inseguras según el estándar PCI-DSS, por lo que mi objetivo posterior con OpenSCAP será detectar estas debilidades y automatizar su cierre para cumplir con la normativa de seguridad exigida.



```
root@localhost:~# nano /etc/ssh/sshd_config
# This is the sshd system wide configuration file.

# The following section can be used to fine tune the configuration on a
# per host basis. You may want to place this file in a directory like
# /etc/ssh/sshd_config.d and include various fragments which end in
# .conf and which are then included into the main file using the
# Include directive.

# To change the default settings, uncomment one or more of the
# following lines that are commented (in this file) with a leading
# '#'.

# Port 22
#Port 22

# Address of all interface ( wildcard or no address )
# Listen *
# Listen 0.0.0.0
# Listen ::
# Listen :::

# Protocol 2,3
#Protocol 2,3

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

# Host-based authentication:
#HostbasedAuthentication no
# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication yes
#PermitEmptyPasswords no

# MaxAuthTries 6
#MaxSessions 10

# PubkeyAuthentication yes

# The default is to check both .ssh/authorized_keys and .ssh/authorized_keys2
# but this is overridden so installations will only check .ssh/authorized_keys
AuthorizedKeysFile .ssh/authorized_keys

# AuthorizedPrincipalsFile none

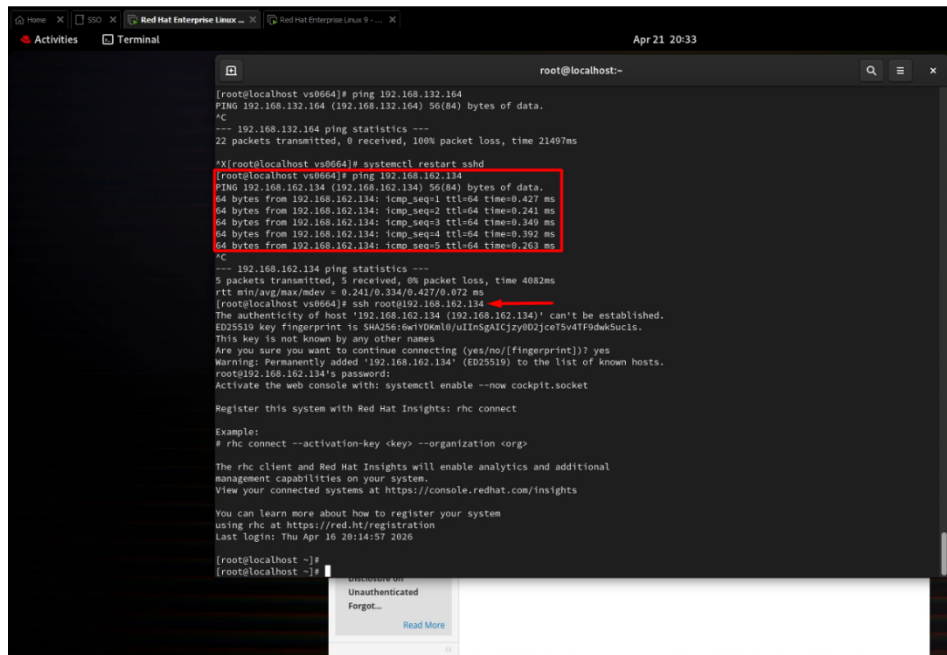
# AuthorizedKeysCommand none
# AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
# HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
# IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication yes
#PermitEmptyPasswords no

# Change to no to disable s/key-passwds
#KbdInteractiveAuthentication yes
```

Paso 11: Ejecuto un ping 192.168.162.134 para confirmar la latencia mínima entre nodos y procedo a realizar una conexión vía ssh root@192.168.162.134.



A terminal window titled 'root@localhost:~' showing the execution of several commands. The first command is 'ping 192.168.162.134', which returns statistics for 22 packets. The second command is 'systemctl restart sshd'. The third command is 'ping 192.168.162.134', which returns statistics for 5 packets. The fourth command is 'ssh root@192.168.162.134', which prompts for a password and shows a warning about the host's authenticity. The terminal output is as follows:

```
[root@localhost ~]# ping 192.168.162.134
PING 192.168.162.134 (192.168.162.134) 56(84) bytes of data.
^C
--- 192.168.162.134 ping statistics ---
22 packets transmitted, 0 received, 100% packet loss, time 21497ms

*[root@localhost ~]# systemctl restart sshd
[root@localhost ~]# ping 192.168.162.134
PING 192.168.162.134 (192.168.162.134) 56(84) bytes of data.
64 bytes from 192.168.162.134: icmp_seq=1 ttl=64 time=0.427 ms
64 bytes from 192.168.162.134: icmp_seq=2 ttl=64 time=0.241 ms
64 bytes from 192.168.162.134: icmp_seq=3 ttl=64 time=0.349 ms
64 bytes from 192.168.162.134: icmp_seq=4 ttl=64 time=0.392 ms
64 bytes from 192.168.162.134: icmp_seq=5 ttl=64 time=0.263 ms
^C
--- 192.168.162.134 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4092ms
rtt min/avg/max/mdev = 0.241/0.334/0.427/0.072 ms
[root@localhost ~]# ssh root@192.168.162.134
Warning: Permanently added '192.168.162.134' (ED25519) to the list of known hosts.
ED25519 key fingerprint is SHA256:6wTVdKml0uIInsgAICjzy0D2jce5v4TF9dwkSueis.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.162.134' (ED25519) to the list of known hosts.
root@192.168.162.134's password:
Activate the web console with: systemctl enable --now cockpit.socket

Register this system with Red Hat Insights: rhc connect

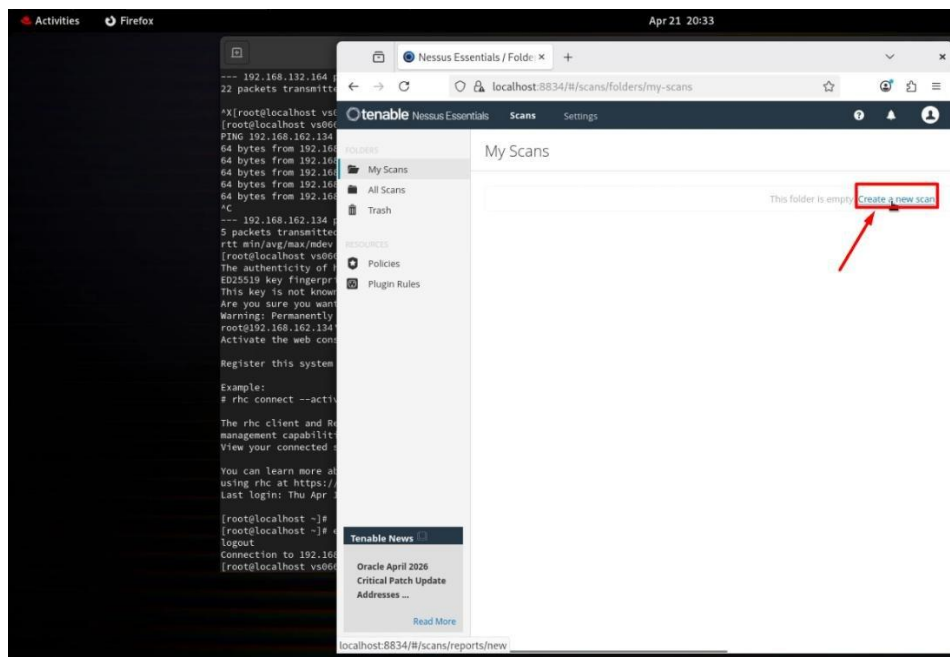
Example:
# rhc connect --activation-key <key> --organization <org>

The rhc client and Red Hat Insights will enable analytics and additional
management capabilities on your system.
View your connected systems at https://console.redhat.com/insights

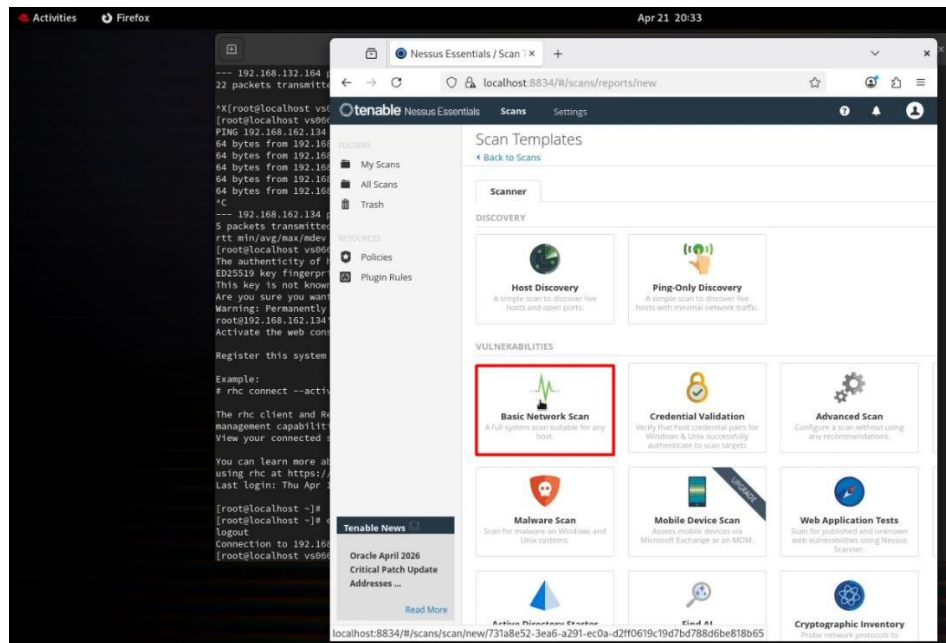
You can learn more about how to register your system
using rhc at https://redhat.com/registration
Last login: Thu Apr 16 20:14:57 2026

[root@localhost ~]#
```

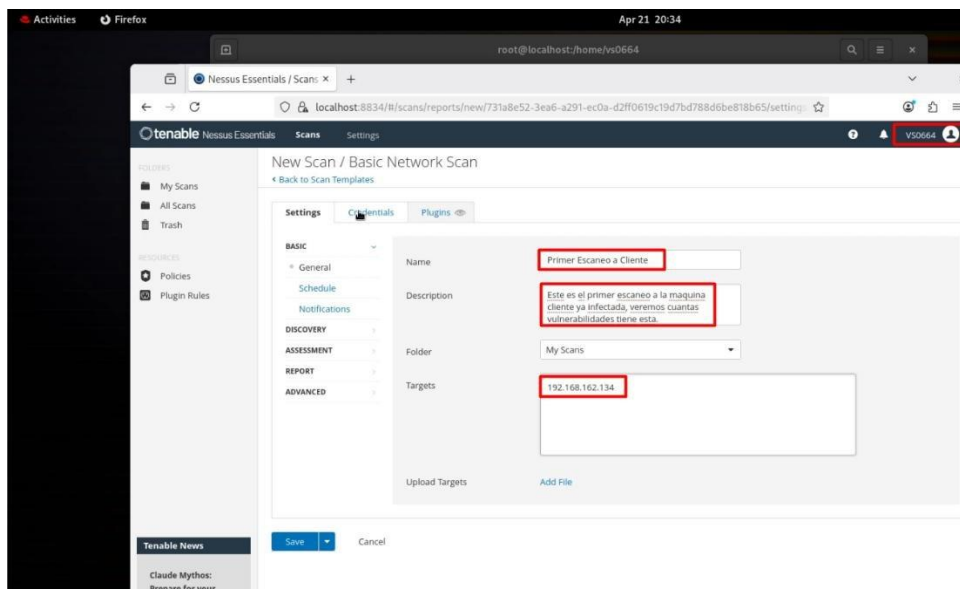
Paso 12: Dentro de la consola de Tenable Nessus, hago clic en el botón "Create a new scan" ubicado en la esquina superior derecha de la sección "My Scans". Este es el punto de partida para definir una auditoría personalizada que me permita mapear la superficie de ataque inicial del cliente, cumpliendo con el requisito de identificar vulnerabilidades antes de la aplicación de parches.



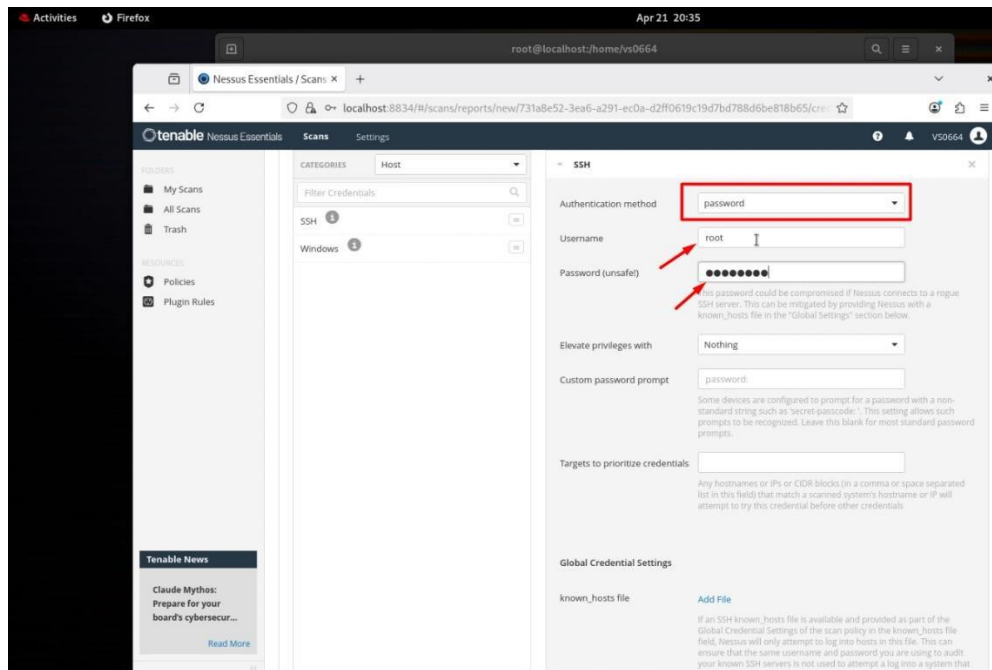
Paso 13: Seleccione la plantilla "Basic Network Scan" del catálogo de Nessus, la cual es ideal para realizar una evaluación completa del sistema adecuada para cualquier host.



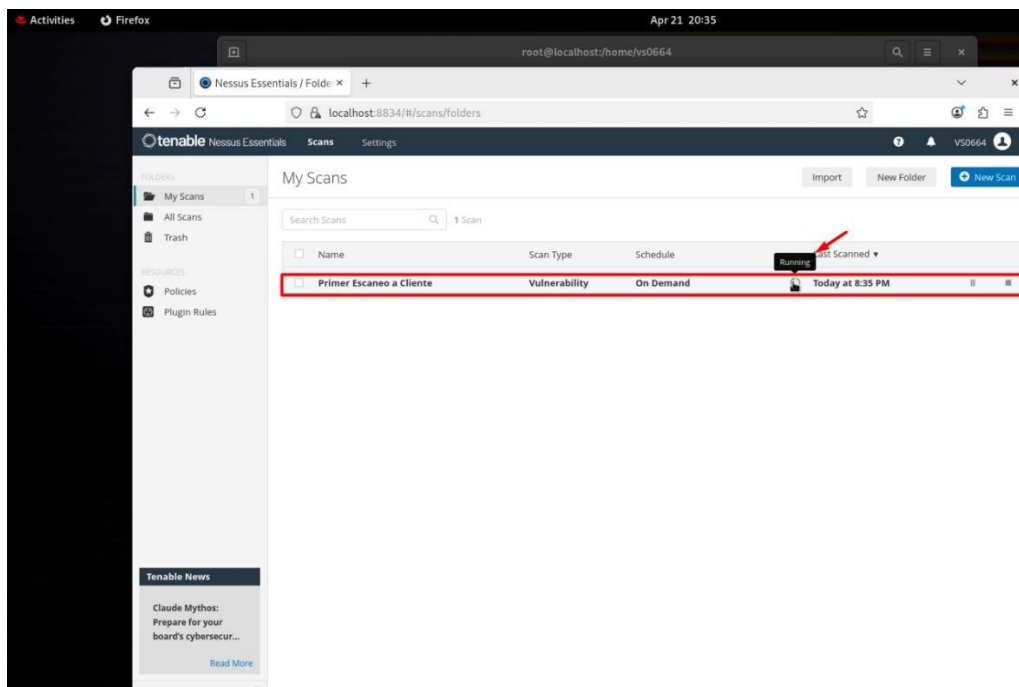
Paso 14: Configuro los detalles del análisis nombrandolo como "Primer Escaneo a Cliente" y asigno la IP 192.168.162.134 en el campo de "Targets". En la descripción detallo que se trata de una máquina con vulnerabilidades provocadas, asegurando que el escaneo esté correctamente dirigido para obtener un reporte detallado de las brechas de seguridad existentes en el nodo.



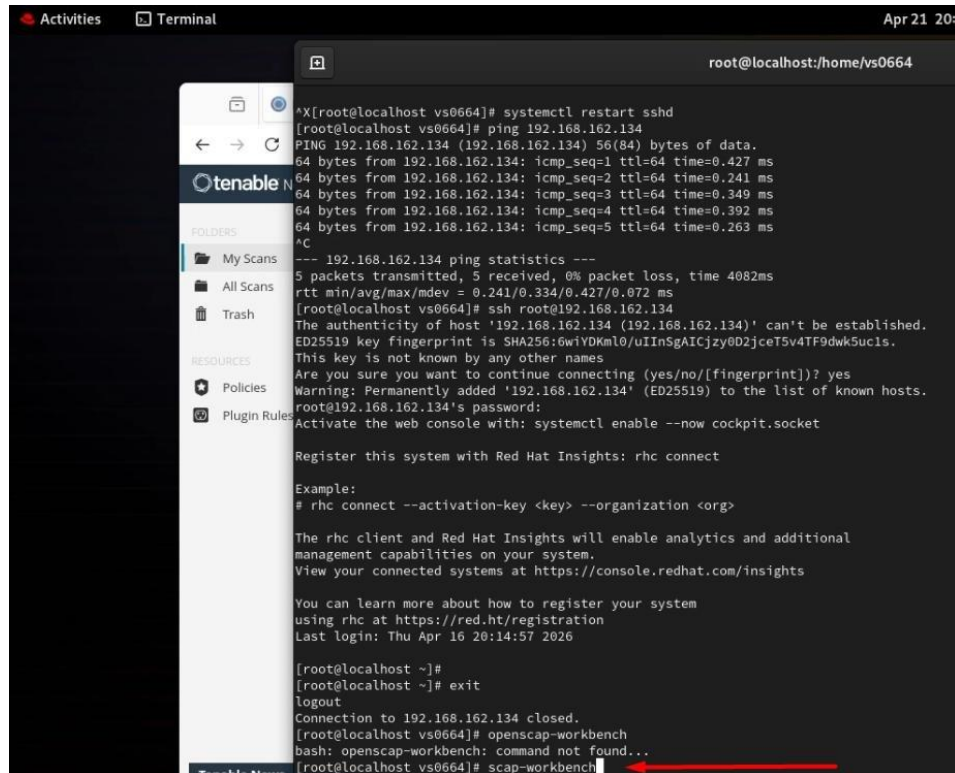
Paso 15: En la pestaña "Credentials", selecciono el método de autenticación por password e ingreso el usuario root con su respectiva contraseña para permitir un escaneo con privilegios elevados.



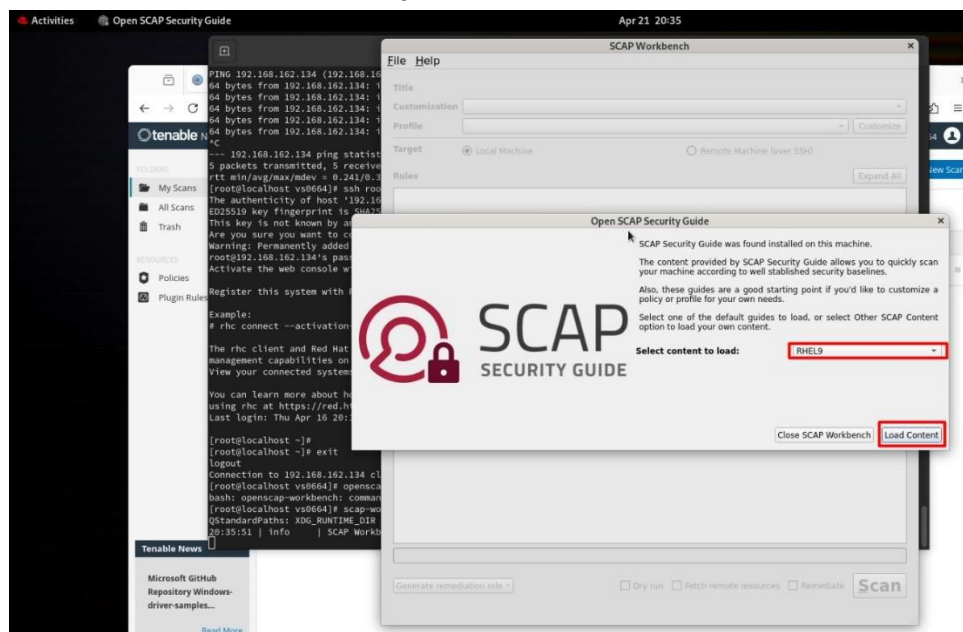
Paso 16: Inicio el escaneo y monitoreo su progreso en la tabla de "My Scans", donde observo que el estado ha cambiado a "Running".



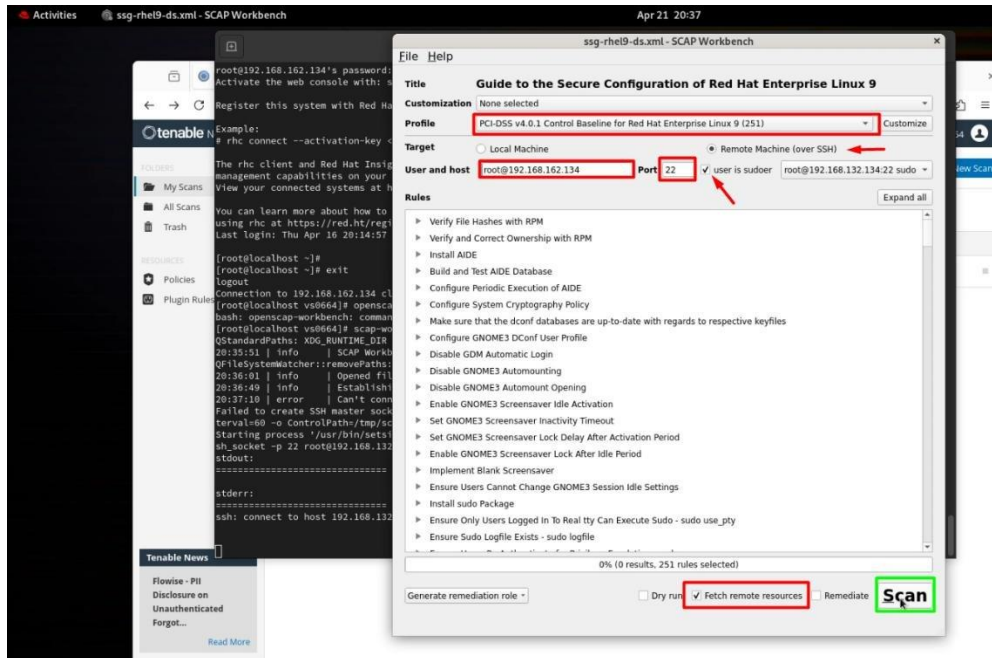
Paso 17: inicio la herramienta gráfica mediante el comando `scap-workbench`. Observo en la terminal que la aplicación se inicializa cargando las librerías de Qt 5.15.2 y el motor OpenSCAP 1.3.13, lo que me da acceso al entorno visual.



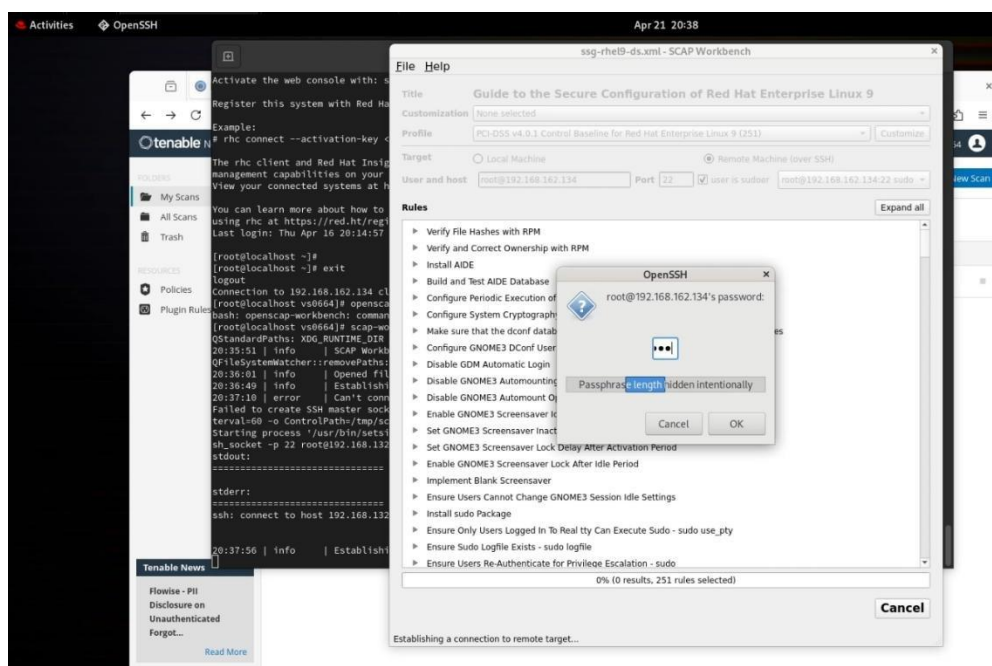
Paso 18: Al abrir el SCAP Workbench, el sistema detecta las guías instaladas y selecciono el contenido "RHEL9" para cargar las políticas específicas de esta distribución. Al hacer clic en "Load Content", la herramienta importa todas las definiciones XCCDF y OVAL que me permitirán auditar el sistema cliente bajo los perfiles de cumplimiento oficiales de Red Hat y la industria financiera.



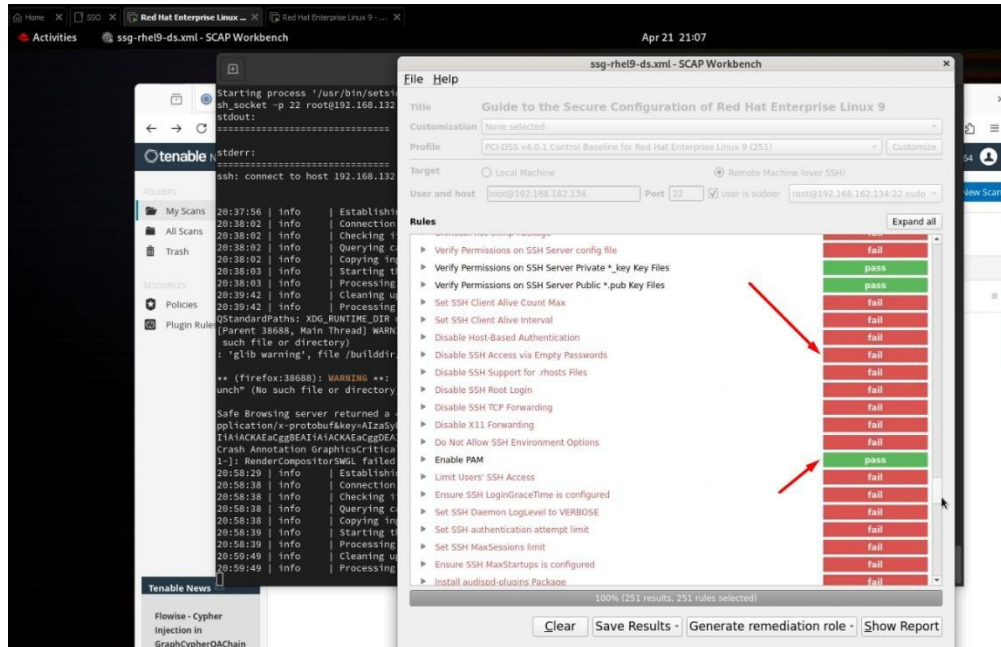
Paso 19: Selecciono el perfil "PCI-DSS v4.0.1 Control Baseline" y cambio el objetivo a "Remote Machine (over SSH)" indicando la dirección root@192.168.162.134. Marco la casilla "user is sudoer" y activo "Fetch remote resources" antes de presionar Scan.



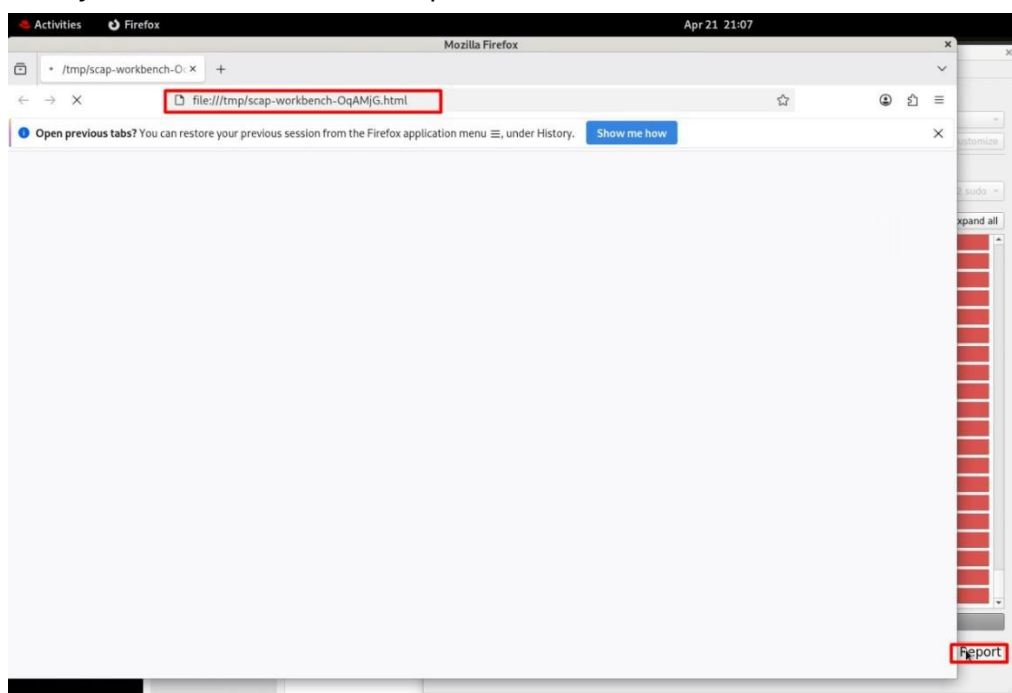
Paso 20: Monitoreo los logs en tiempo real donde se confirma que la conexión se ha establecido y el sistema está "Checking if oscap is available on remote machine, iniciando el análisis exhaustivo de los 251 puntos de control que exige el estándar PCI-DSS.



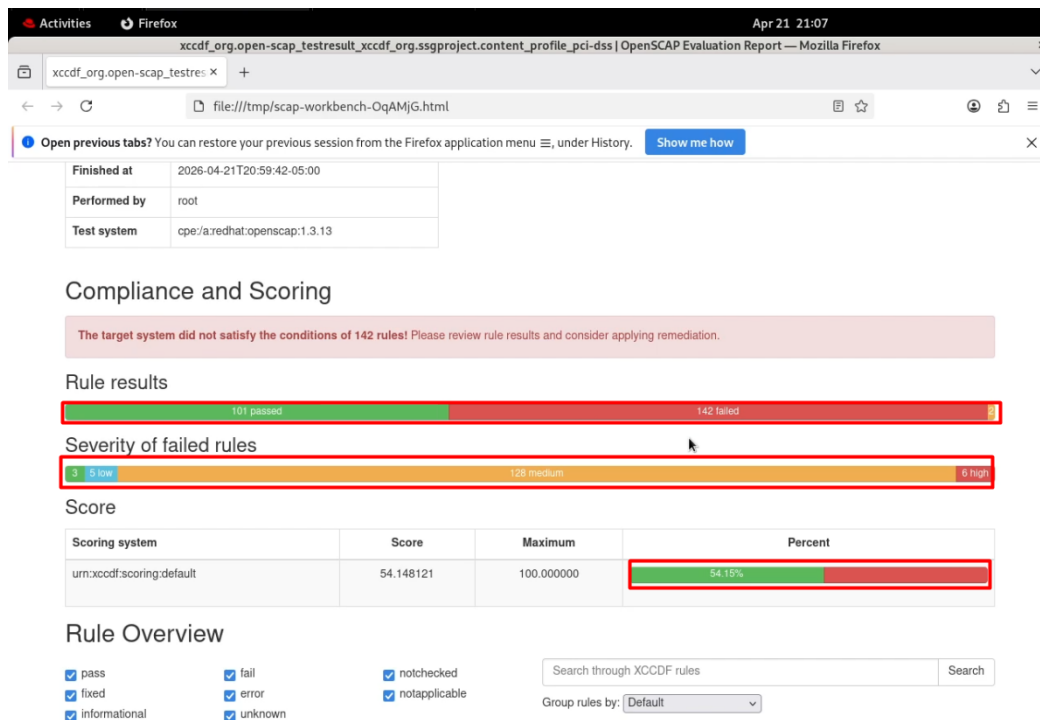
Paso 21: Tras completar el escaneo, la interfaz de SCAP Workbench muestra un predominio de indicadores rojos etiquetados como "fail". Identifico fallos críticos en la configuración de SSH y acceso de usuarios, confirmando que el cliente no cumple con la mayoría de las reglas de seguridad exigidas por el perfil PCI-DSS v4.0.1.



Paso 22: Hago clic en el botón "Show Report" para exportar los hallazgos detallados a un formato legible. El sistema genera automáticamente un archivo HTML en el directorio temporal, el cual servirá como evidencia documentada de las vulnerabilidades y el estado actual de cumplimiento del servidor auditado.



Paso 23: Reviso el reporte en el navegador, observando una puntuación de 54.15%. El sistema detalla que el target no satisfizo 142 reglas, clasificando la severidad de los fallos principalmente como de nivel "medium", lo que subraya la necesidad inmediata de aplicar las remediaciones sugeridas por la herramienta.



Paso 24: Analizo las reglas específicas que fallaron, como la expiración de cuentas tras inactividad y la prevención de inicios de sesión con contraseñas vacías.

Activities Firefox Apr 21 21:08

xccdf_org.open-scap_testresult_xccdf_org.ssgproject.content_profile_pci-dss | OpenSCAP Evaluation Report — Mozilla Firefox

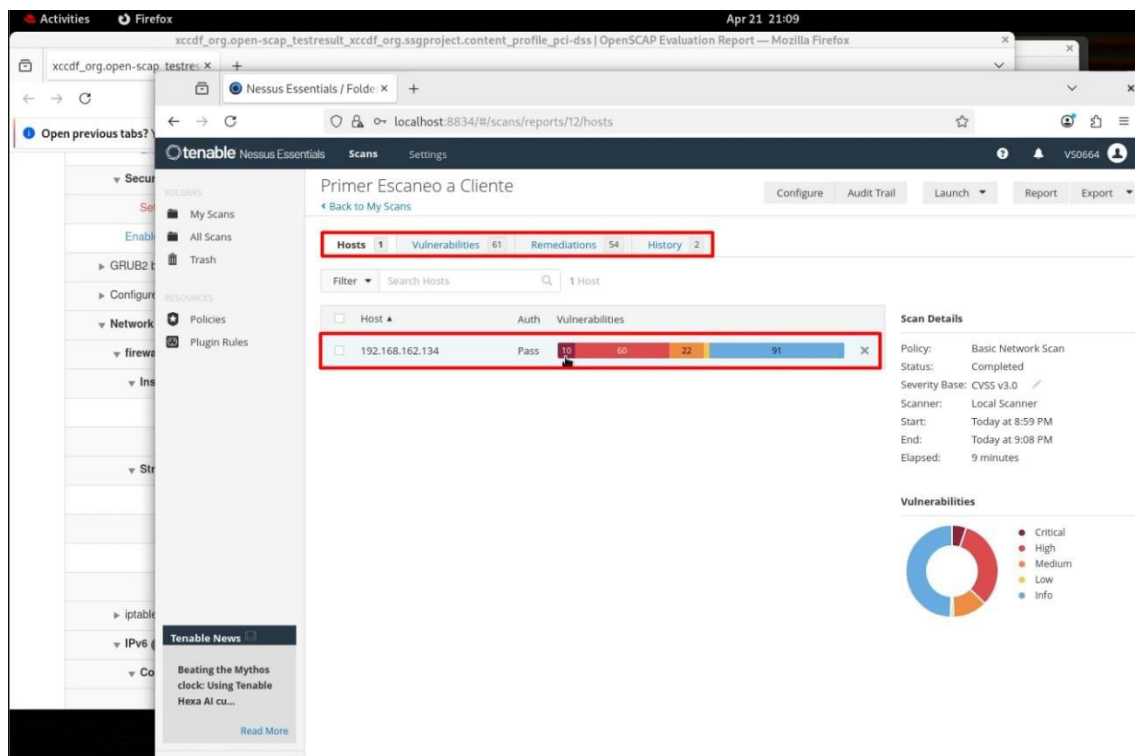
xccdf_org.open-scap_testres: x +

file:///tmp/scap-workbench-QqAMjG.html

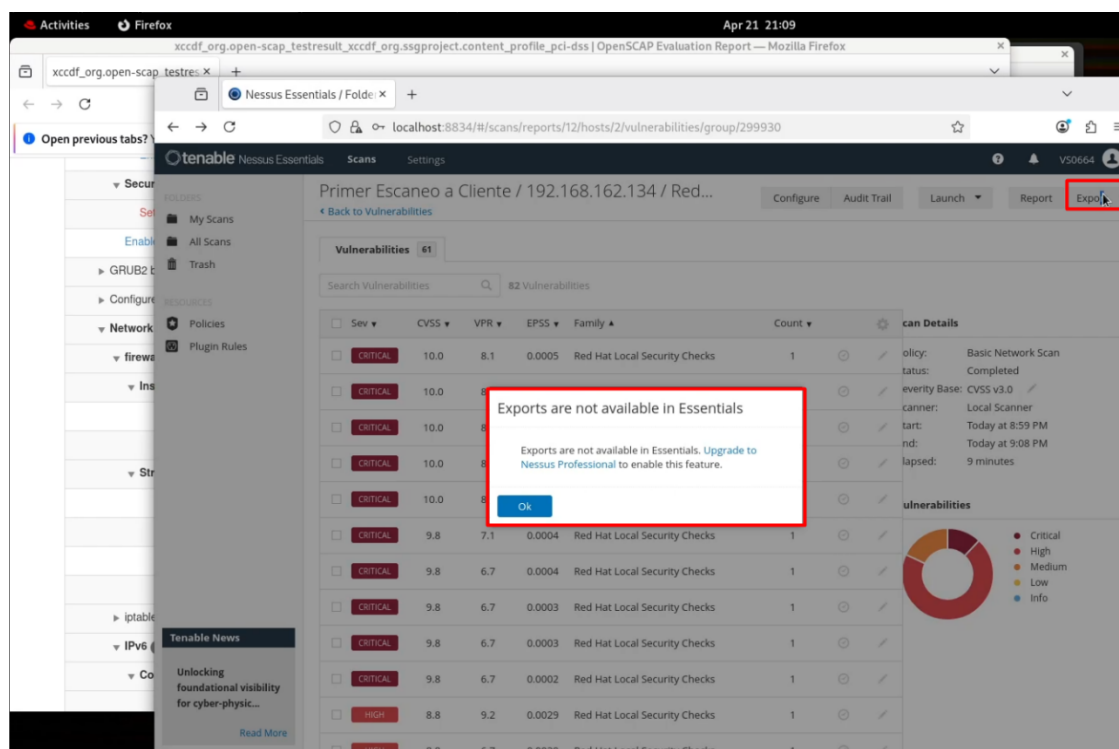
Open previous tabs? You can restore your previous session from the Firefox application menu ≡, under History. Show me how

Rule	Severity	Status
Set Account Expiration Parameters (1x fail)		
Set Account Expiration Following Inactivity	medium	fail
Ensure All Accounts on the System Have Unique Names	medium	pass
Set Password Expiration Parameters (2x fail)		
Set Password Maximum Age	medium	fail
Set Existing Passwords Maximum Age	medium	fail
Set Existing Passwords Warning Age	medium	pass
Set Password Warning Age	medium	pass
Set existing passwords a period of inactivity before they been locked	medium	pass
Verify Proper Storage and Existence of Password Hashes (3x fail)		
Verify All Account Password Hashes are Shadowed	medium	pass
Ensure all users last password change date is in the past	medium	fail
All GIDs referenced in /etc/passwd must be defined in /etc/group	low	pass
Prevent Login to Accounts With Empty Password	high	fail
Ensure There Are No Accounts With Blank or Null Passwords	high	fail
Restrict Root Logins (2x fail)		
Verify Only Root Has UID 0	high	pass
Verify Root Has A Primary GID 0	high	pass
file:///tmp/scap-workbench-QqAMjG.html#rule-detail-idm46007592752064_vists on System and is Empty	medium	fail

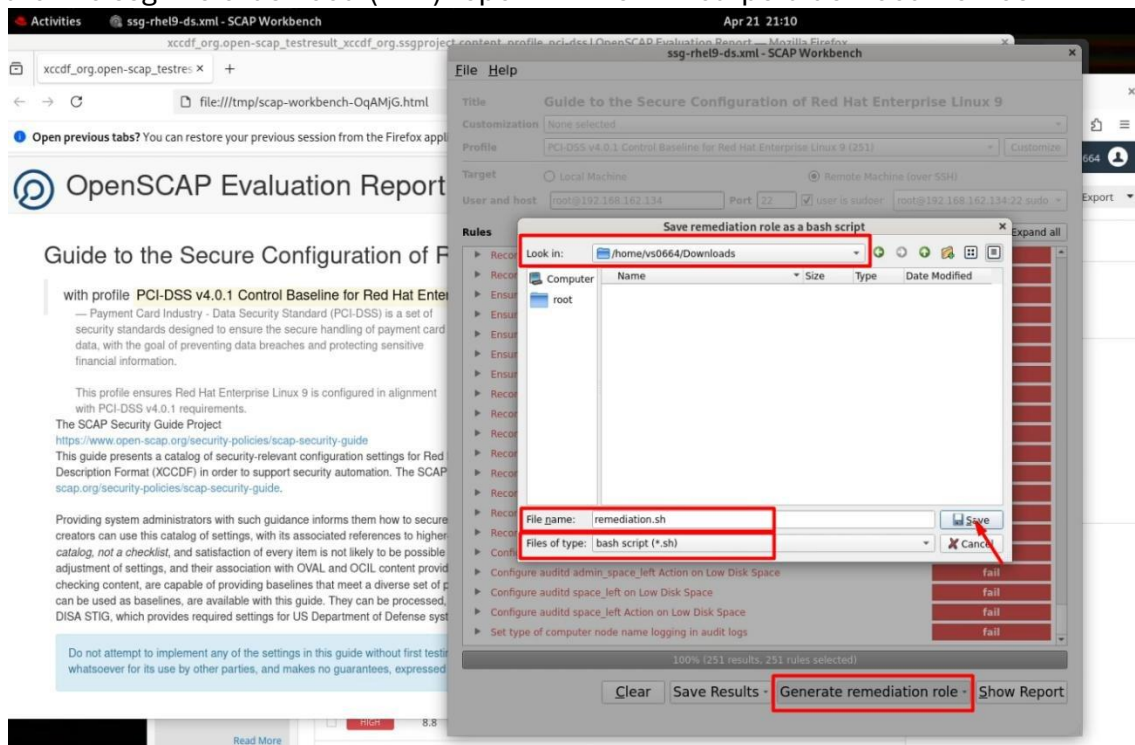
Paso 25: Regreso a la consola de Nessus, donde el reporte final indica 61 vulnerabilidades totales encontradas en el host 192.168.162.134. La gráfica muestra un alto volumen de riesgos de nivel medio, alto y bajo.



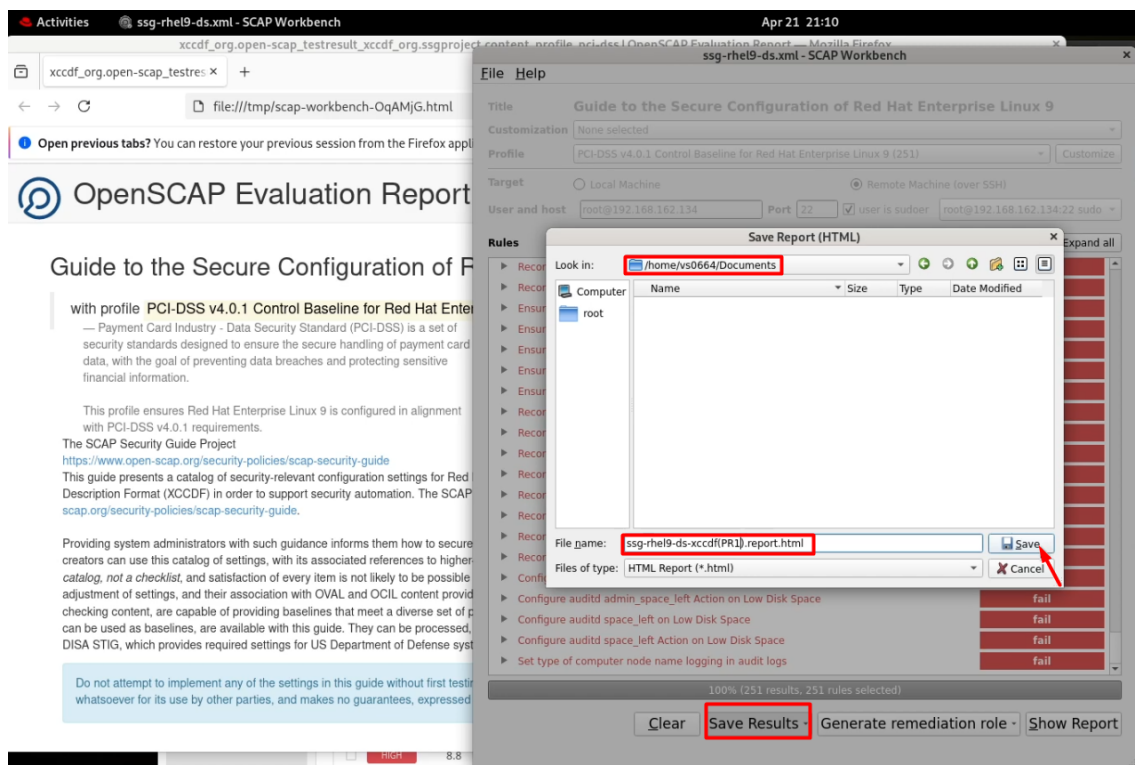
Paso 26: Al intentar exportar el reporte desde Nessus, el sistema muestra un aviso indicando que "Exports are not available in Essentials". Eso es para gente con otro plan que no sea el mio.



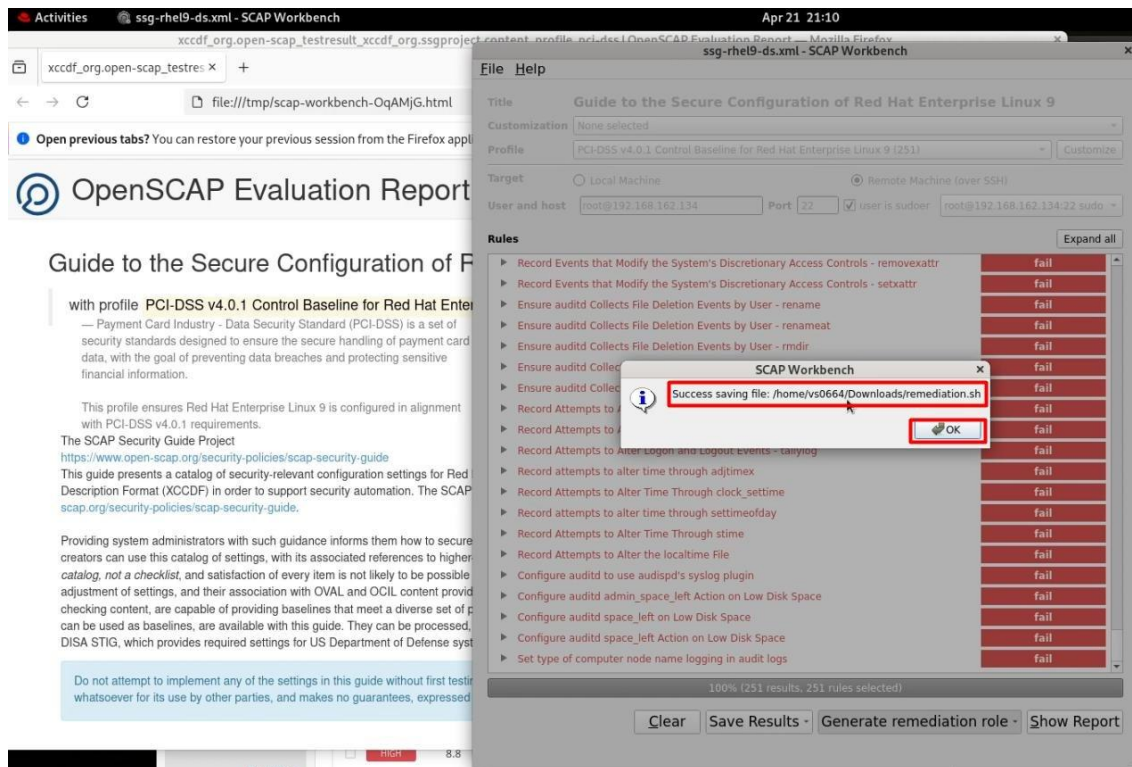
Paso 27: Utilizo la opción "Save Results" en SCAP Workbench para almacenar el archivo `ssg-rhel9-ds-xccdf(PR1).report.html` en mi carpeta de Documentos.



Paso 28: Selecciono la opción "Generate remediation role" y elijo el formato bash script (.sh), nombrando al archivo como `remediation.sh`. Este script contiene todos los comandos necesarios para corregir automáticamente los fallos detectados y alinear el sistema cliente con los estándares de PCI-DSS.

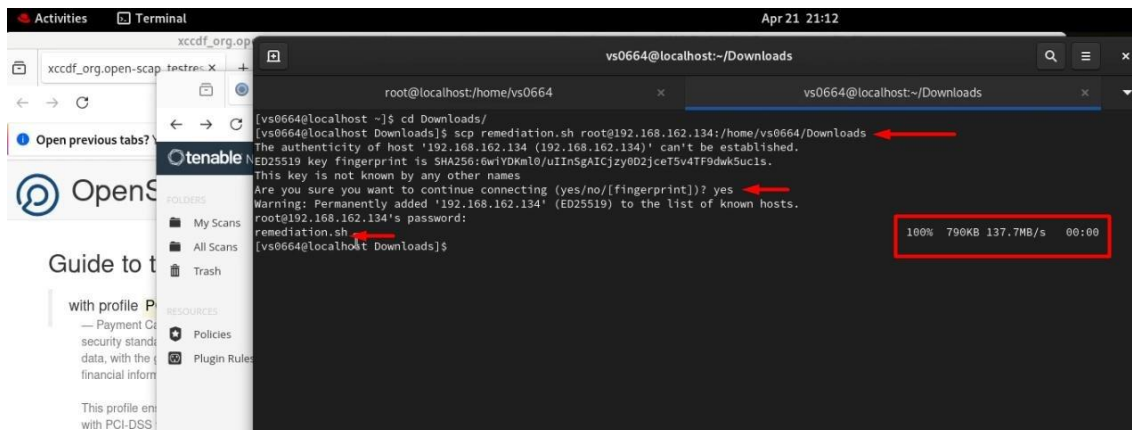


Paso 29: El sistema me muestra una ventana de confirmación indicando el éxito en el guardado del archivo en la ruta /home/vs0664/Downloads/remediation.sh.

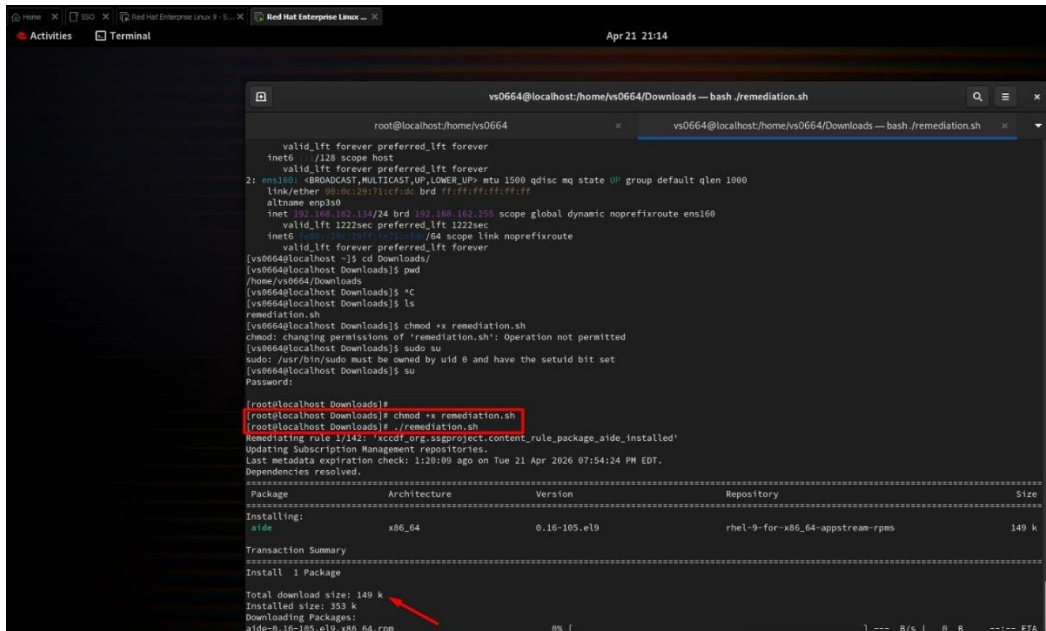


Paso 30: Ejecuto el comando scp remediation.sh

root@192.168.162.134:/home/vs0664/Downloads para enviar el script al equipo cliente. Confirmo la autenticidad del host y observo la transferencia exitosa al 100%, dejando el archivo de remediación listo para ser ejecutado en el nodo destino.



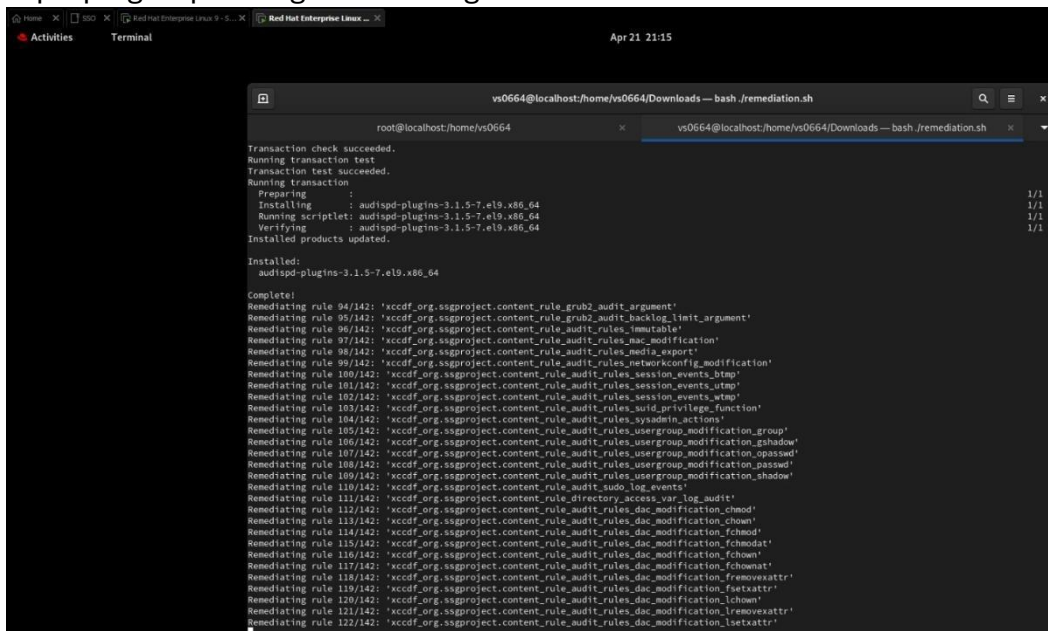
Paso 31: En la terminal del cliente, otorgo permisos de ejecución con `chmod +x remediation.sh` y lanzo el script mediante `./remediation.sh`. Observo cómo el sistema inicia la instalación de paquetes de seguridad necesarios, como `aide`, y comienza a procesar automáticamente cada una de las 142 reglas de cumplimiento detectadas como fallidas anteriormente.



```
root@localhost/home/vs0664
vs0664@localhost/home/vs0664/Downloads — bash ./remediation.sh

valid_lft forever preferred_lft forever
inet6 ::128 scope host
    valid_lft forever preferred_lft forever
2: ens160: BROADCAST,MULTICAST,UP,LOWER_UP  mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:0c:29:17:1c:5d brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    inet 192.168.1.1/24 brd 192.168.1.255 scope global dynamic noprefixroute ens160
        valid_lft 1222sec preferred_lft 1222sec
    inet6 fe80::20c:29ff:fe17:1c5d/64 scope link noprefixroute
    valid_lft forever preferred_lft forever
[vs0664@localhost ~]$ cd Downloads/
[vs0664@localhost Downloads]$ pwd
/home/vs0664/Downloads
[vs0664@localhost Downloads]$ ^C
[vs0664@localhost Downloads]$ ls
remediation.sh
[vs0664@localhost Downloads]$ chmod +x remediation.sh
chmod: changing permissions of './remediation.sh': operation not permitted
[vs0664@localhost Downloads]$ sudo su
sudo: /usr/bin/sudo must be owned by uid 0 and have the setuid bit set
[vs0664@localhost Downloads]$ su
Password:
root@localhost Downloads#
root@localhost Downloads# chmod +x remediation.sh
root@localhost Downloads# ./remediation.sh
Remediating rule 1/142: 'xccdf_org.ssgproject.content_rule_package_aide_installed'
Updating Subscription Management repositories.
Last metadata expiration check: 1:20:09 ago on Tue 21 Apr 2026 07:54:24 PM EDT.
Dependencies resolved.
=====
Package                Architecture      Version            Repository          Size
=====
Installing:
aide                   x86_64            0.16-105.el9      rhel-9-for-x86_64-appstream-rpms 149 k
=====
Transaction Summary
=====
Install 1 Package
Total download size: 149 k
Installed size: 353 k
Downloading Packages:
aide-0.16-105.el9.x86_64.rpm
=====
```

Paso 32: El script continúa su ejecución instalando complementos críticos como `audispd-plugins` para la gestión de logs de auditoría.



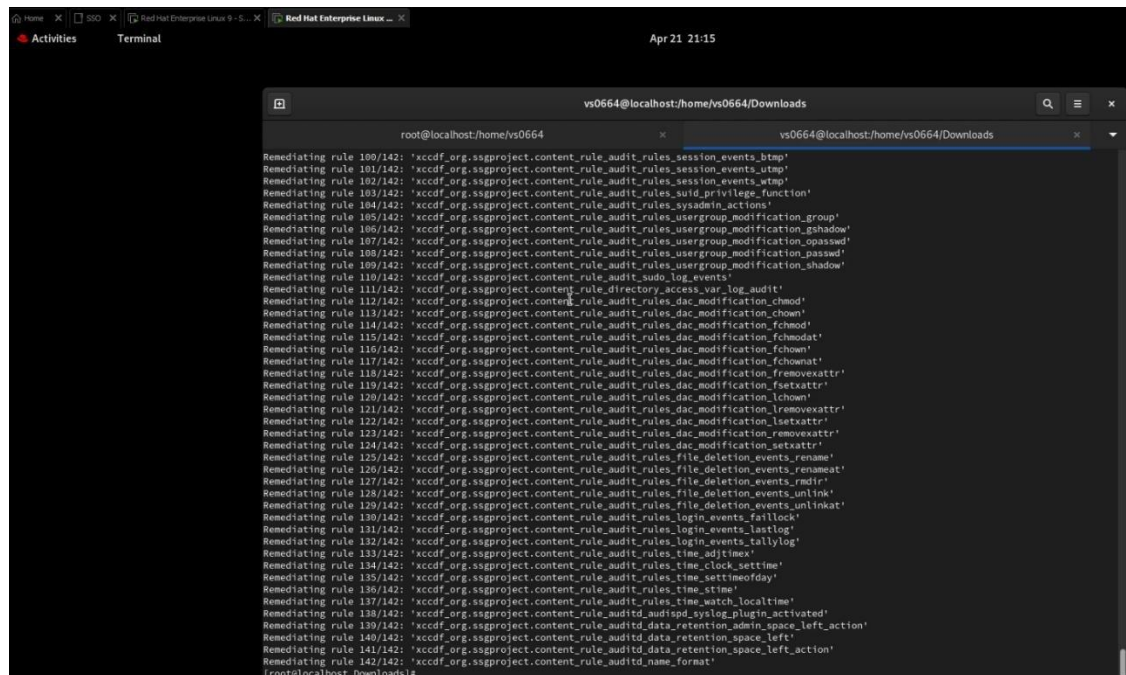
```
vs0664@localhost/home/vs0664/Downloads — bash ./remediation.sh

Transaction check succeeded.
Running transaction test
Transaction test succeeded.
Running transaction
  Preparing                : 1/1
  Installing audispd-plugins-3.1.5-7.el9.x86_64 : 1/1
  Running scriptlet: audispd-plugins-3.1.5-7.el9.x86_64 : 1/1
  Verifying                : 1/1
Installed products updated.

Installed:
  audispd-plugins-3.1.5-7.el9.x86_64

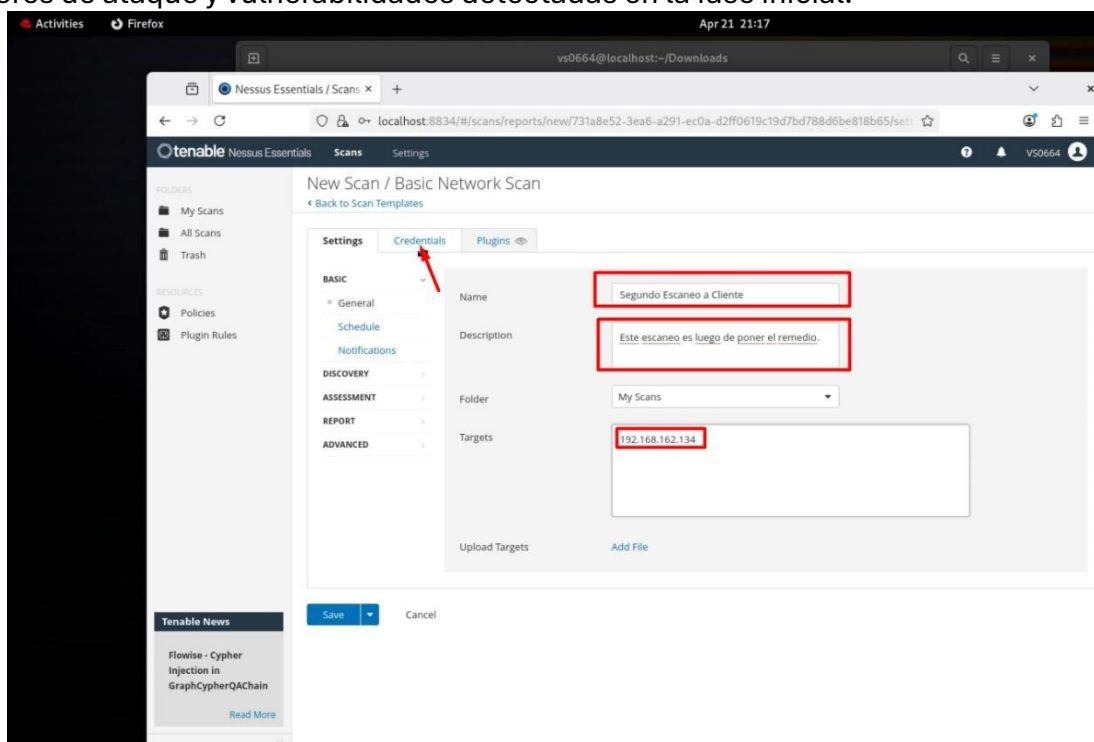
Completed
Remediating rule 94/142: 'xccdf_org.ssgproject.content_rule_grub2_audit_argument'
Remediating rule 95/142: 'xccdf_org.ssgproject.content_rule_grub2_audit_backlog_limit_argument'
Remediating rule 96/142: 'xccdf_org.ssgproject.content_rule_audit_rules_Immutable'
Remediating rule 97/142: 'xccdf_org.ssgproject.content_rule_audit_rules_mac_modification'
Remediating rule 98/142: 'xccdf_org.ssgproject.content_rule_audit_rules_media_export'
Remediating rule 99/142: 'xccdf_org.ssgproject.content_rule_audit_rules_networkconfig_modification'
Remediating rule 100/142: 'xccdf_org.ssgproject.content_rule_audit_rules_session_events_ftp'
Remediating rule 101/142: 'xccdf_org.ssgproject.content_rule_audit_rules_session_events_ftp'
Remediating rule 102/142: 'xccdf_org.ssgproject.content_rule_audit_rules_session_events_ftp'
Remediating rule 103/142: 'xccdf_org.ssgproject.content_rule_audit_rules_session_events_ftp'
Remediating rule 104/142: 'xccdf_org.ssgproject.content_rule_audit_rules_sysadmin_action'
Remediating rule 105/142: 'xccdf_org.ssgproject.content_rule_audit_rules_usergroup_modification_group'
Remediating rule 106/142: 'xccdf_org.ssgproject.content_rule_audit_rules_usergroup_modification_shadow'
Remediating rule 107/142: 'xccdf_org.ssgproject.content_rule_audit_rules_usergroup_modification_opasswd'
Remediating rule 108/142: 'xccdf_org.ssgproject.content_rule_audit_rules_usergroup_modification_passwd'
Remediating rule 109/142: 'xccdf_org.ssgproject.content_rule_audit_rules_usergroup_modification_shadow'
Remediating rule 110/142: 'xccdf_org.ssgproject.content_rule_audit_rules_log_events'
Remediating rule 111/142: 'xccdf_org.ssgproject.content_rule_audit_rules_directory_access_var_log_audit'
Remediating rule 112/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_chmod'
Remediating rule 113/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_chown'
Remediating rule 114/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_fchmod'
Remediating rule 115/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_fchmodat'
Remediating rule 116/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_fchown'
Remediating rule 117/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_fchownat'
Remediating rule 118/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_fremovexattr'
Remediating rule 119/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_fsetxattr'
Remediating rule 120/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_lchown'
Remediating rule 121/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_lremovexattr'
Remediating rule 122/142: 'xccdf_org.ssgproject.content_rule_audit_rules_dac_modification_lsetxattr'
```

Paso 33: Tras varios minutos de procesamiento intensivo, el script alcanza la regla final 142/142, cubriendo aspectos desde la retención de datos hasta el formato de nombres de auditoría.

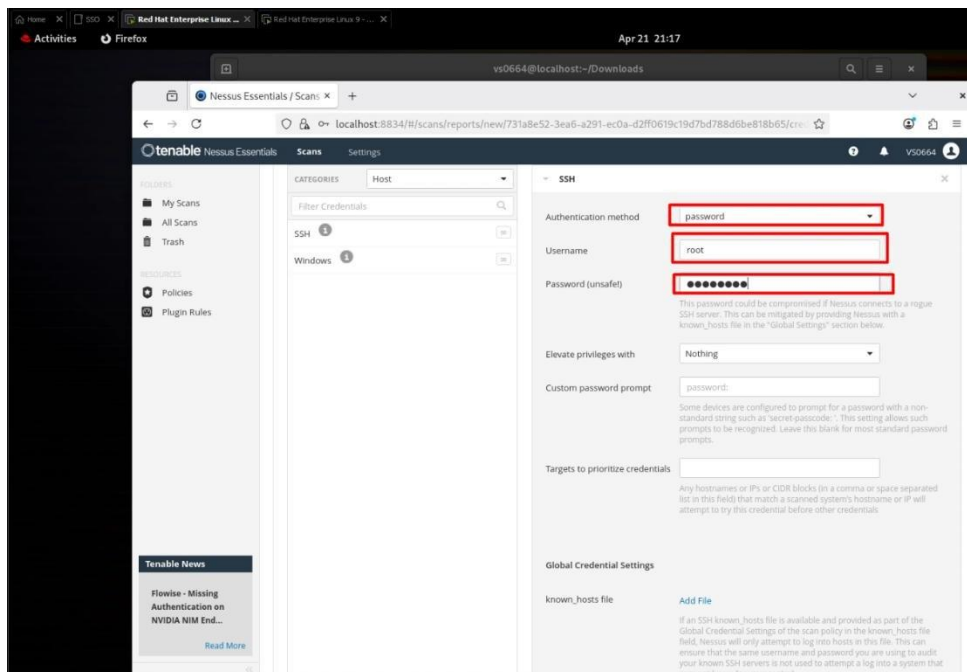


A terminal window titled 'vs0664@localhost/home/vs0664/Downloads' showing a list of remediation rules. The rules are numbered from 100/142 to 142/142. Each rule is followed by a command in single quotes, such as 'xccdf_org.ssgproject.content_rule_audit_rules_session_events_btmp'. The terminal output shows the progress of the script as it applies these rules.

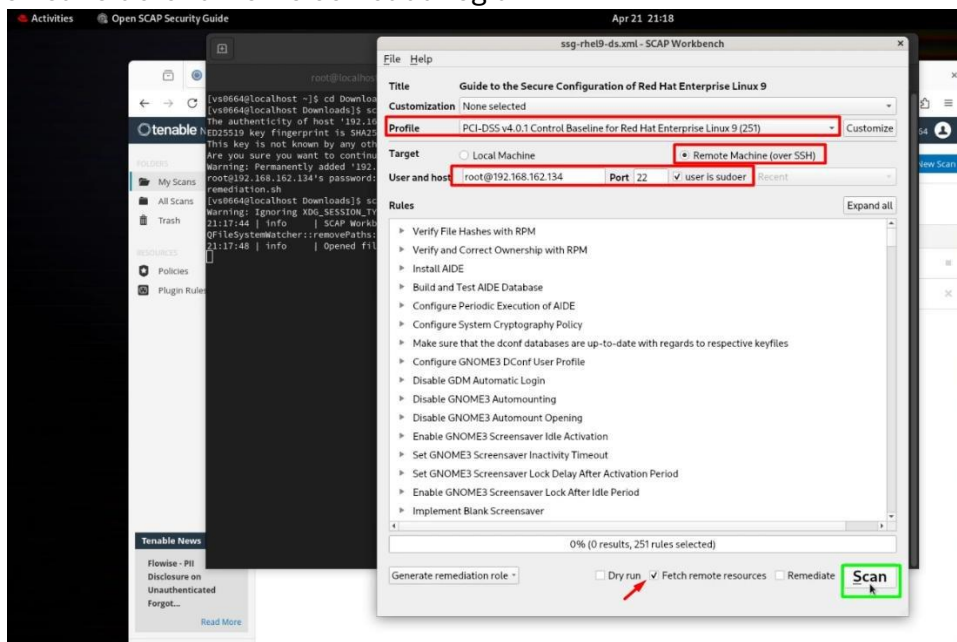
Paso 34: Regreso a la consola de Nessus para crear una nueva auditoría denominada "Segundo Escaneo a Cliente", manteniendo el objetivo en la IP 192.168.162.134. El propósito de esta tarea es validar externamente que las remediaciones aplicadas por el script de OpenSCAP han cerrado efectivamente los vectores de ataque y vulnerabilidades detectadas en la fase inicial.



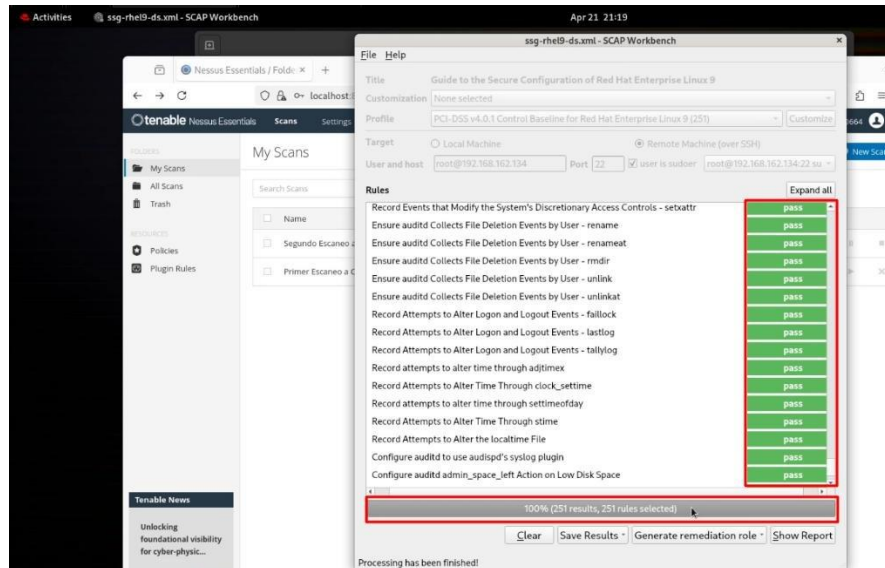
Paso 35: Pongo mis credenciales en SSH, y el método de autenticar sería contraseña y usuario, y luego aceptamos.



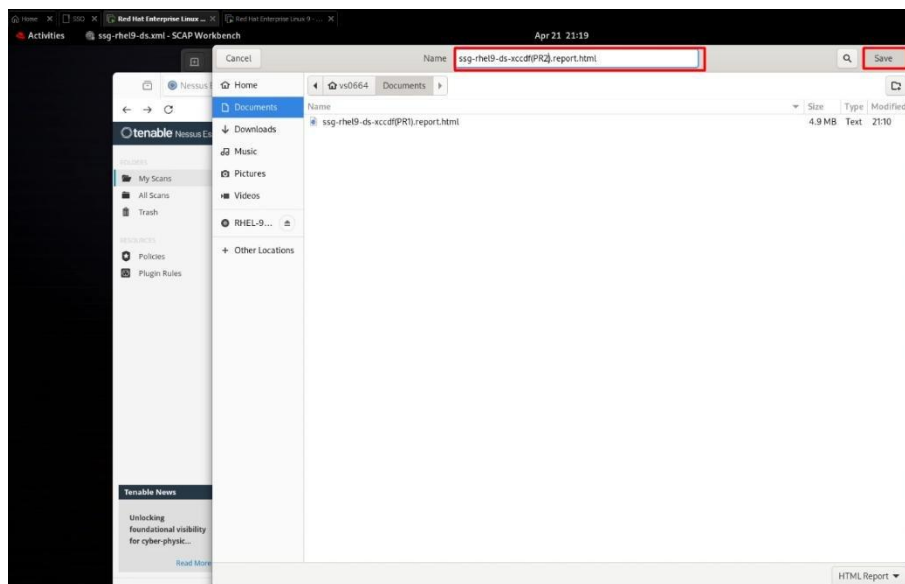
Paso 36: Vuelvo al SCAP Workbench y configuro nuevamente el escaneo remoto sobre el perfil PCI-DSS. Me aseguro de marcar la casilla "Fetch remote resources" y presiono Scan; esta segunda vuelta es crucial para que el motor de cumplimiento verifique de manera interna si los cambios realizados por el script de bash ahora cumplen satisfactoriamente con cada regla.



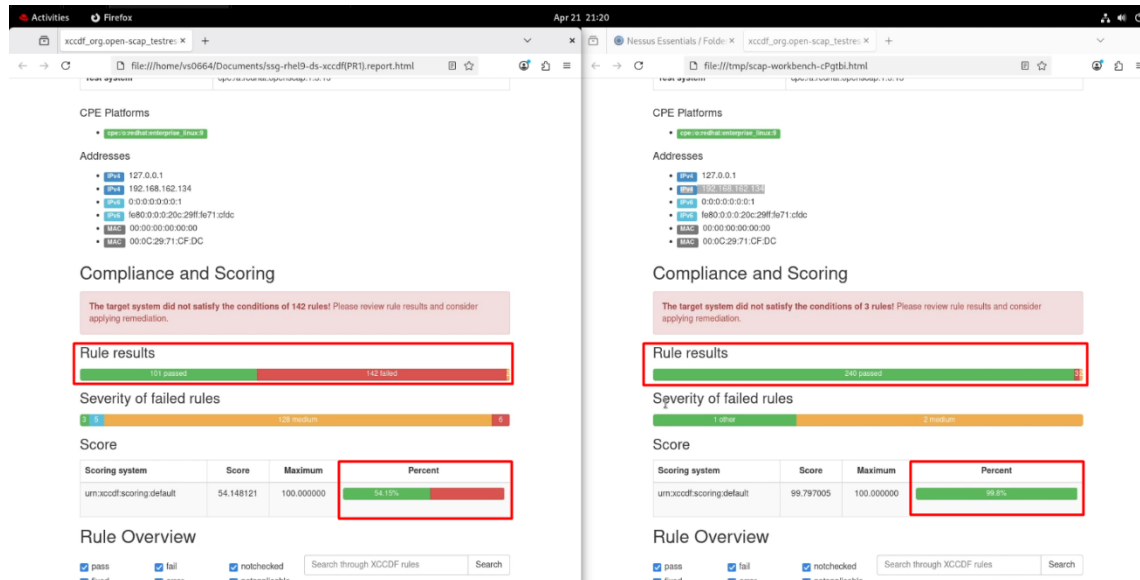
Paso 37: Observo con satisfacción cómo la lista de reglas ahora muestra un estado masivo de "pass" en color verde. El sistema confirma que las políticas de auditoría, logs de eliminación de archivos y controles de tiempo han sido corregidos, alcanzando el cumplimiento total de los 251 puntos de control seleccionados en el perfil de seguridad de tarjetas de crédito.



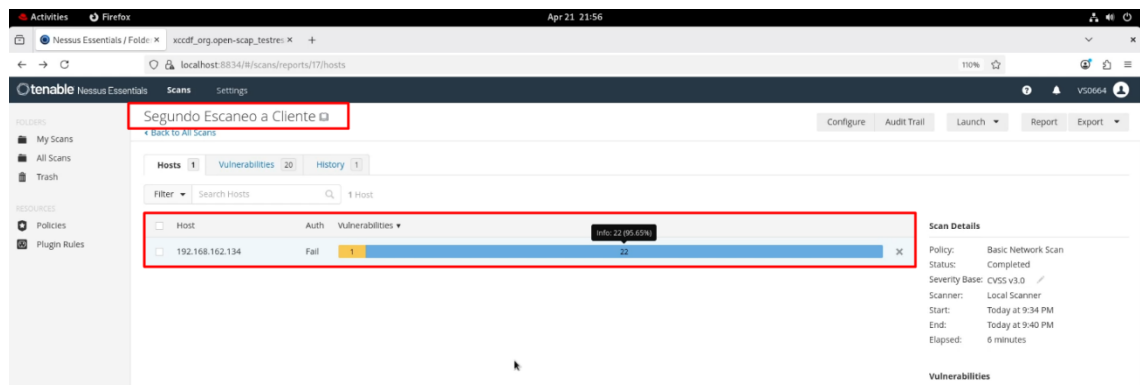
Paso 38: Procedo a guardar el nuevo reporte bajo el nombre ssg-rhel9-ds-xccdf(PR2).report.html en mi carpeta de Documentos.



Paso 39: Realizo una comparación visual entre ambos reportes HTML: el inicial con un 54.15% y el final con un impresionante 99.8% de cumplimiento. Esta diferencia técnica demuestra la potencia de OpenSCAP para mitigar riesgos de forma automatizada, dejando apenas un margen mínimo de reglas que requieren intervención manual o que no aplican al entorno.



Paso 40: reviso el "Segundo Escaneo a Cliente" en Nessus, el cual muestra una reducción drástica en la severidad de las vulnerabilidades. Con la mayoría de los riesgos críticos eliminados.



Paso 41: Analizo el reporte del "Primer Escaneo a Cliente" frente al segundo, destacando que inicialmente el host 192.168.162.134 presentaba 10 vulnerabilidades críticas y 60 altas.

Nessus Essentials / Folder: x

localhost:8834/#/scans/reports/12/hosts

tenable Nessus Essentials Scans Settings

Primer Escaneo a Cliente

Configure Audit Trail

Back to My Scans

Hosts 1 Vulnerabilities 61 Remediations 54 History 2

Filter Search Hosts 1 Host

Host	Auth	Vulnerabilities
192.168.162.134	Pass	10 60 22 91

Paso 42: Concluyo la práctica implementando un flujo de trabajo donde OpenSCAP gestiona el cumplimiento normativo (PCI-DSS) y Nessus audita la superficie de ataque activa.

